KOMINFO

PANDUAN PENGISIAN TOOLS ASESMEN IMPLEMENTASI PELINDUNGAN DATA PRIBADI

Direktorat Pengendalian Aplikasi Informatika
Direktorat Jenderal Aplikasi Informatika
Kementerian Komunikasi dan Informatika

Panduan ini dapat diakses secara gratis melalui https://komin.fo/toolsasesmenpdp, dapat digandakan dan disebarluaskan, namun tidak untuk diperjualbelikan. Konten dirumuskan pada Oktober 2021 dan merupakan subjek terhadap perubahan. Jika terdapat perubahan konten akan dituangkan dalam panduan baru dan mengakibatkan tidak berlakunya panduan ini.

SISTEMATIKA PANDUAN

DASAR HUKUM 4

DAFTAR ISTILAH 5

PANDUAN PENGISIAN 8

A. Prinsip-prinsip Pemrosesan Data Pribadi

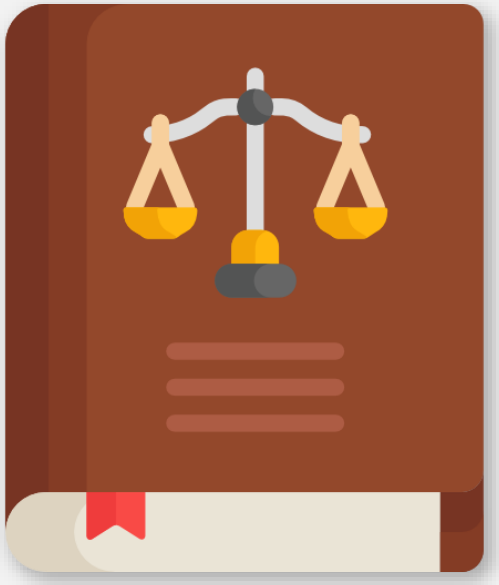
1. Pemrosesan Data Pribadi 12
2. Relevansi Tujuan Pemrosesan dan Perolehan Data Pribadi 31
3. Jaminan Hak Pemilik Data Pribadi 36
4. Keakuratan Data Pribadi 46
5. Langkah Pengamanan Data Pribadi 49
6. Informasi Pemrosesan Data Pribadi 64
7. Pemusnahan/Penghapusan Data Pribadi 77

B. Pengiriman dan Pengungkapan Data Pribadi 84

Hasil Asesmen Implementasi Pelindungan Data Pribadi 91

KONTAK TIM PENGAWASAN PDP 95

Dasar Hukum



- Undang-Undang Nomor 11 Tahun 2008 tentang Informasi Elektronik sebagaimana diubah oleh Undang-Undang Nomor 19 Tahun 2016.
- Peraturan Pemerintah Nomor 71 Tahun 2019 tentang Penyelenggaraan Sistem dan Transaksi Elektronik.
- Peraturan Menteri Kominfo Nomor 20 Tahun 2016 tentang Perlindungan Data Pribadi Dalam Sistem Elektronik.
- Peraturan Menteri Kominfo Nomor 5 Tahun 2020 tentang Penyelenggara Sistem Elektronik Lingkup Privat sebagaimana diubah terakhir dengan PermenKominfo 10 Tahun 2021.

DAFTAR ISTILAH

Akses	:	Kegiatan melakukan interaksi dengan sistem elektronik yang berdiri sendiri atau dalam jaringan.
Cookies/Internet Cookies	:	File teks yang disimpan oleh penyedia situs web di komputer pengguna situs web yang dapat diakses kembali oleh penyedia situs web tersebut ketika pengguna mengunjungi situs web pada kesempatan lainnya, yang digunakan untuk memfasilitasi penyelenggaraan Internet atau transaksi, atau untuk mengakses informasi tentang perilaku pengguna.
Dasar Legalitas (lawful bases)	:	Ketentuan peraturan perundang-undangan yang menjadi dasar syarat sahnya pemrosesan data pribadi, antara lain, adanya persetujuan (*consent*) dari pemilik daya, kewajiban pelaksanaan kontrak hukum yang nyata, pemenuhan kewajiban atau kewenangan hukum, kepentingan yang sah lainnya, dan lainnya. Setiap pihak dilarang memproses data pribadi kecuali adanya dasar legalitas kegiatan pemrosesannya.
Data Pribadi	:	Data tentang seseorang baik yang teridentifikasi dan/atau dapat diidentifikasi secara tersendiri atau dikombinasi dengan informasi lainnya baik secara langsung maupun tidak langsung melalui sistem elektronik dan/atau non-elektronik.
DPO	:	*Data Protection Officer* atau *Pejabat atau Petugas Yang Melaksanakan Fungsi Pelindungan Data Pribadi.*
K/L	:	Kementerian atau Lembaga.
Kominfo	:	Kementerian Komunikasi dan Informatika, khususnya, Direktorat Pengendalian Aplikasi Informatika, Sub-Direktorat yang bertugas dalam pengendalian data pribadi.

DAFTAR ISTILAH

Hak Pemilik Data	:	Hak yang dimiliki pemilik data pribadi yang ditetapkan berdasarkan ketentuan peraturan perundang-undangan mengenai pelindungan data pribadi di Indonesia, antara lain, hak mendapatkan akses, hak meminta pemusnahan/penghapusan, hak meminta dikeluarkan dari daftar mesin pencari, hak atas kerahasiaan data, hak mengajukan pengaduan ke otoritas yang berwenang, hak mendapatkan pemberitahuan terjadinya kegagalan/gangguan PDP, dan lainnya.
Pemrosesan/Memproses	:	Pengumpulan, pengolahan, penganalisisan, penyimpanan, penampilan, pengumuman, pengiriman, penyebarluasan, dan pemusnahan data pribadi.
Pengguna	:	Setiap orang perseorangan, instansi penyelenggara negara, badan usaha, dan masyarakat yang memanfaatkan barang, jasa, fasilitas, atau informasi yang disediakan oleh PSE
PDP	:	Pelindungan Data Pribadi
Profiling		Segala bentuk pemrosesan otomatis data pribadi yang mengevaluasi aspek pribadi pemilik data, khususnya menganalisis atau memprediksi aspek yang berkaitan dengan kinerja orang perseorangan di tempat kerja, situasi ekonomi, kesehatan, preferensi atau minat pribadi, konsistensi tindakan atau perilaku, lokasi atau pergerakan, yang tindakan pemrosesan otomatis tersebut memiliki akibat hukum tertentu atau berdampak secara signifikan bagi pemilik data pribadi.
PSE atau Anda	:	Penyelenggara Sistem Elektronik Lingkup Privat dan Lingkup Publik.
Subyek/Pemilik Data Pribadi	:	Orang perseorangan dengan data pribadi yang melalui pemrosesan.
TDPSE	:	Tanda daftar PSE.
URL Website	:	*Uniform Resource Locator Website*.

Tool Assessment Implementasi PDP atau ***Tool*** adalah dokumen yang disusun untuk mengetahui tingkat kepatuhan PSE terhadap ketentuan peraturan perundang-undangan di bidang PDP. Penyelenggara Sistem Elektronik ("**PSE**"), baik PSE Lingkup Publik dan PSE Lingkup Privat, wajib melaksanakan pelindungan data pribadi dalam melakukan pemrosesan data pribadi pada sistem elektronik yang berada dalam kuasa atau kendalinya sebagaimana diwajibkan dalam Undang-Undang No. 11 Tahun 2008 Tentang Informasi dan Transaksi Elektronik sebagaimana diubah oleh Undang-Undang No. 19 Tahun 2016 **("UU ITE")**, Peraturan Pemerintah Nomor 71 Tahun 2019 Tentang Penyelenggaraan Sistem dan Transaksi Elektronik **("PP 71/2019")**, Peraturan Menteri Komunikasi dan Informatika Nomor 20 Tahun 2016 Tentang Perlindungan Data Pribadi Dalam Sistem Elektronik **("PM 20/2016")**, dan Peraturan Menteri Komunikasi dan Informatika Nomor 5 Tahun 2020 Tentang Penyelenggara Sistem Elektronik Lingkup Privat jo. Peraturan Menteri Komunikasi dan Informatika Nomor 10 Tahun 2021 **("PM 5/2020")**.

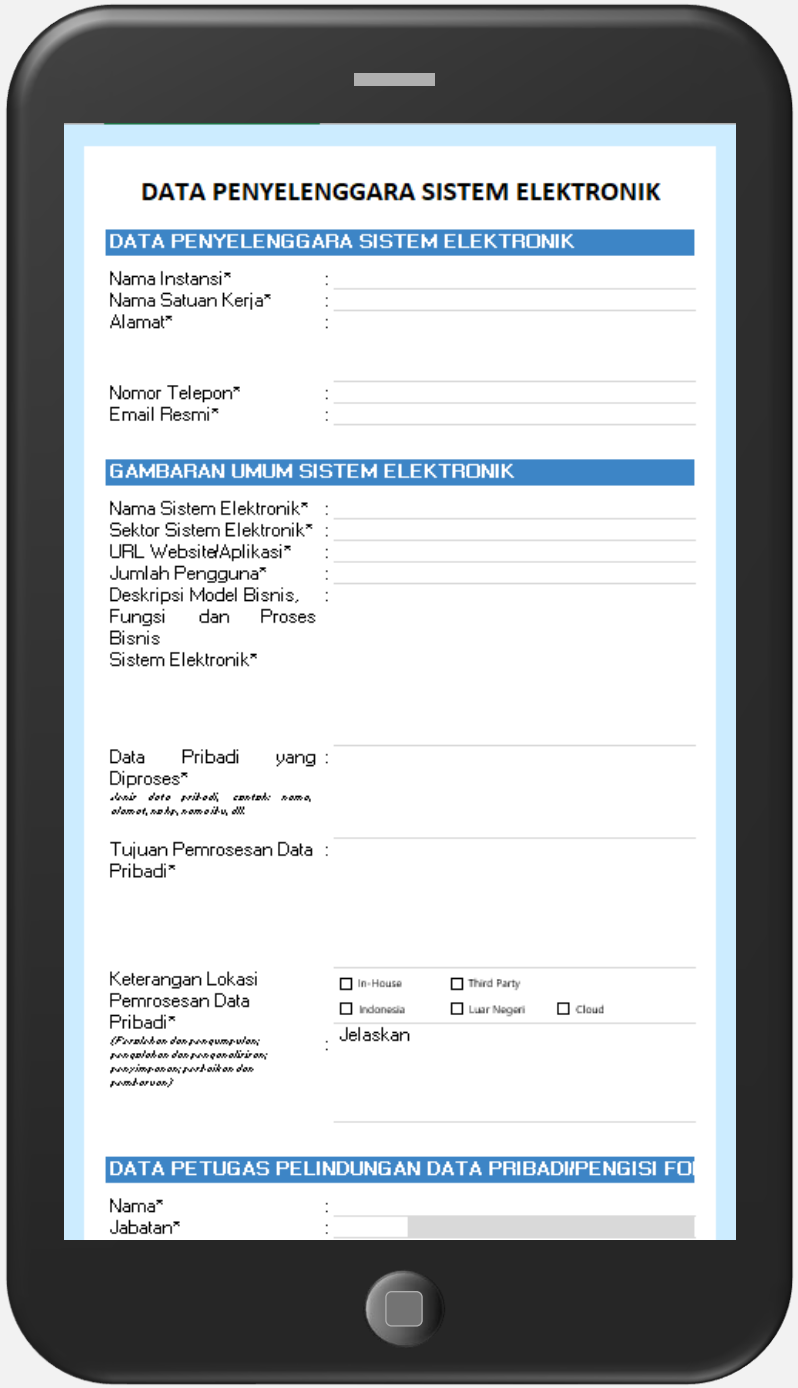
PSE Lingkup Privat meliputi:

- PSE yang diatur dan diawasi oleh K/L berdasarkan peraturan perundang-undangan.
- PSE yang memiliki portal, situs, atau aplikasi dalam jaringan melalui Internet yang dipergunakan untuk, antara lain, penawaran dan/atau perdagangan barang dan/atau jasa, layanan transaksi keuangan, pengiriman muatan digital berbayar, layanan komunikasi dalam jaringan dalam bentuk platform digital, layanan jejaring, dan media sosial, layanan mesin pencari, layanan penyediaan informasi elektronik, pemrosesan data pribadi.

PSE Lingkup Publik adalah instansi penyelenggara negara dan institusi yang ditunjuk oleh instansi tersebut.

Berdasarkan UU ITE dan PP 71/2019, setiap PSE harus menyelenggarakan sistem elektronik secara **andal** dan **aman** serta **bertanggung jawab** terhadap beroperasinya sistem elektronik sebagaimana mestinya.

PANDUAN PENGISIAN



DATA PENYELENGGARA SISTEM ELEKTRONIK

DATA PENYELENGGARA SISTEM ELEKTRONIK

Nama Instansi* :
Nama Satuan Kerja* :
Alamat* :

Nomor Telepon* :
Email Resmi* :

GAMBARAN UMUM SISTEM ELEKTRONIK

Nama Sistem Elektronik* :
Sektor Sistem Elektronik* :
URL Website/Aplikasi* :
Jumlah Pengguna* :
Deskripsi Model Bisnis, Fungsi dan Proses Bisnis Sistem Elektronik* :

Data Pribadi yang Diproses* :
Jenis data pribadi, contoh: nama, alamat, nasb, nomeiku, dll.

Tujuan Pemrosesan Data Pribadi* :

Keterangan Lokasi Pemrosesan Data Pribadi* :
(Perolehan dan pengumpulan; pengolahan dan penganalisian; penyimpanan; perbaikan dan pembaruan)

☐ In-House ☐ Third Party
☐ Indonesia ☐ Luar Negeri ☐ Cloud
Jelaskan

DATA PETUGAS PELINDUNGAN DATA PRIBADI/PENGISI FO

Nama* :
Jabatan* :

ISIAN IDENTITAS PSE DAN KEGIATAN PEMROSESAN DATA PRIBADI

PSE menguraikan gambaran umum sistem elektroniknya seakurat dan selengkap mungkin.

PSE menyebutkan narahubung, DPO, *Chief Privacy Officer*, atau pejabat lainnya yang bertanggung jawab atas PDP.

PSE menyebutkan jenis data pribadi yang diperoleh dan kategori pemilik data (contoh: pelanggan, karyawan, dewasa, anak-anak, dan seterusnya).

PSE menyebutkan kegiatan utama bisnis atau layanannya, serta kegiatan penunjang yang memproses data pribadi.

KETENTUAN PENGGUNAAN

Tool dapat diakses melalui https://komin.fo/toolsasesmenpdp. Untuk menggunakannya, PSE terlebih dahulu memasukkan data tentang penyelenggaraan sistem elektronik yang terdiri dari nama perusahaan, nomor TDPSE, alamat, email, gambaran umum sistem elektroniknya, serta data petugas pelindungan data pribadi/pengisi *Toolkit*.

Tool menanyakan sejumlah pertanyaan kepada PSE mengenai implementasi prinsip-prinsip pemrosesan dan pengiriman serta pengungkapan data pribadi, termasuk hak pemilik data, tata kelola dan akuntabilitas pemrosesan. Apabila PSE membutuhkan penjelasan lebih terkait suatu pertanyaan, silahkan membaca penjelasan dalam Panduan ini yang memuat praktik yang baik *(good practices)* dengan contoh praktis yang relevan atas setiap pertanyaan.

Setelah PSE mengisinya, *Tool* akan menampilkan laporan hasil pengisian PSE dan saran praktis (atau tingkat lanjut) untuk meningkatkan kepatuhan PSE terhadap ketentuan PDP. Akan tetapi, pemenuhan saran ini atau pengisian *Tool* ini tidak menjamin bahwa kegiatan pemrosesan data pribadi oleh PSE telah memenuhi ketentuan PDP berdasarkan peraturan perundang-undangan. Kami menyarankan PSE untuk berkonsultasi dengan kami atau pihak ketiga lain yang memiliki kompetensi dan kualifikasi yang cukup untuk memberikan advis tentang PDP dalam kegiatan pemrosesan PSE.

Kami merahasiakan dan melindungi data yang diisi oleh PSE dalam *Tool*.

Tool tidak dimaksudkan untuk menggantikan atau membebaskan setiap tanggung jawab dan kewajiban PSE yang ditentukan dalam peraturan perundang-undangan, termasuk kewajiban tanggung jawab pengamanan data dan memiliki DPO (jika berlaku). *Tool* ini bertujuan menjadi bahan pertimbangan awal bagi PSE dalam merencanakan dan mengimplementasikan PDP dalam kegiatan pemrosesannya.

Setiap pertanyaan dalam *Tool* harus Anda jawab dengan jawaban YA atau TIDAK.

Contoh:

Apakah pemrosesan Data Pribadi dilakukan atas dasar sah secara hukum, khususnya, Persetujuan yang Sah dari Subyek Data?

- *Jawab **YA** jika Persetujuan dari Subyek Data yang menjadi dasar legalitas pemrosesan data pribadi.*
- *Jawab **TIDAK** jika bukan Persetujuan dari Subyek Data yang menjadi dasar legalitas pemrosesan data pribadi, tapi dasar legalitas lain, antara lain, pemenuhan kewajiban perjanjian, pemenuhan kewajiban hukum, atau pelaksanaan kewenangan pengendali data (PSE).*

PILIH JAWABAN Ya / Tidak yang berarti:

Ya : ADA PRAKTIK PDP

Tidak : TIDAK ADA PRAKTIK PDP

A. PRINSIP-PRINSIP PEMROSESAN DATA PRIBADI

BAGIAN 01

Pemrosesan Data Pribadi

1.1. Apakah pengumpulan data pribadi dilakukan secara adil?

Pemrosesan yang adil (*fairness*) artinya pemilik data mengetahui kegiatan pemrosesan data pribadinya dengan cukup memadai, seperti bagaimana proses pengumpulan, penyimpanan, dan pemanfaatan data pribadinya, sehingga persetujuan yang sah dapat diberikannya dan mereka dapat menggunakan haknya sebagai pemilik data. Pemrosesan yang adil akan secara otomatis berlaku dalam hal pemrosesan tersebut dilakukan dalam rangka pelaksanaan peraturan perundang-undangan. Pemrosesan yang adil juga mensyaratkan adanya pemeriksaan mengenai akibat pemrosesan tersebut kepada pemilik data.

Praktik yang baik:

- ☑ PSE memastikan kegiatan pemrosesan data pribadi sejalan dengan hukum yang berlaku atau bukan perbuatan yang dilarang;
- ☑ Memberitahukan ke pemilik data mengenai apa yang PSE lakukan terhadap data pribadi, termasuk risiko pemrosesan data pribadi setelah data pribadinya diberikan ke PSE;
- ☑ Memastikan dan melaksanakan transparansi pemrosesan data pribadi; dan
- ☑ Melaksanakan aturan pelindungan data pribadi.
- ☑ Jika pemrosesan berdampak merugikan kepada mereka dan adanya kerugian tersebut tidak dapat dibenarkan secara hukum, maka kegiatan tersebut bukan pemrosesan yang adil (contoh: mengetahui preferensi pengunjung web pemesanan tiket/hotel dengan *cookies* yang berfungsi membuat keputusan otomatis, yaitu pengunjung yang sering mengunjungi harga tiket/hotel tertentu, harga tiket/hotel tersebut dinaikkan secara otomatis).

1.1. Apakah pengumpulan data pribadi dilakukan secara adil?

Contoh:

- PSE yang mengoperasikan portal web telah memasang fitur jendela dialog *pop-up* sebelum pengujung portal tersebut mengakses informasi dalam portal web tersebut. Jendela dialog *pop-up* tersebut menampilkan informasi tentang tujuan dipasangnya *Internet cookies* dan informasi yang dikumpulkan oleh *cookies* tersebut. Jendela dialog tersebut juga ditampilkan seeksplisit mungkin sehingga setiap pengunjung langsung dihadapkan pada informasi tersebut. Selain itu, PSE menampilkan tujuan tersebut secara berlapis-lapis dan terstruktur (semakin dalam pengujung mengakses informasi dalam portal web, maka akan ada jendela *pop-up* atau formulir yang meminta data pribadi pengujung). Penampilan jendela *pop-up* yang eksplisit tersebut adalah wujud pemenuhan prinsip adil dalam pemrosesan. Pengendali juga perlu merinci tujuan pemrosesan data pribadi dan memberikan jaminan atas pelindungan data pribadi (atau mematuhi setiap aturan pelindungan data pribadi).
- PSE memberi opsi kepada pengunjung web untuk memilik fitur *cookies* yang diaktifkan, antara lain, *strictly necessary cookies, analytical or performance cookies, functionality cookies,* atau *targeting cookies.* PSE juga menyampaikan tujuan/kegunaan setiap jenis *cookies* tersebut kepada pengunjung dengan bahasa yang mudah dimengerti.
- Memiliki rekam jejak audit mengenai setiap pihak internal dan eksternal yang memiliki akses ke data pribadi pengguna.
- PSE menyampaikan jangka waktu penyimpanan data pribadi kepada pemilik data serta apakah data pribadinya dapat diakses pihak ketiga/mitra kerja sama PSE, serta seberapa sering mereka mengakses data pribadi.

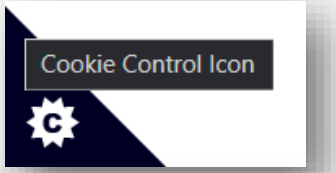
1.2.1 Apakah pemrosesan data pribadi dilakukan sah secara hukum: adanya persetujuan yang sah dari pemilik data untuk tujuan tertentu yang telah disampaikan kepada pemilik data?

Sah secara hukum artinya pemrosesan data harus sejalan dengan peraturan perundang-undangan, khususnya menggunakan dasar legalitas pemrosesan (contoh: adanya persetujuan dari pemilik data). Pengendali data konsisten menerapkan dasar legalitas tersebut terhadap kegiatan pemrosesannya. Pemrosesan data harus memenuhi ketentuan adanya persetujuan yang sah dari pemilik data untuk satu atau beberapa tujuan tertentu yang telah disampaikan kepada pemilik data.

Praktik yang baik:

- ☑ Persetujuan yang sah adalah persetujuan yang disampaikan secara eksplisit, tidak boleh secara tersembunyi atau atas dasar kekhilafan, kelalaian atau paksaan.
- ☑ Persetujuan diminta didahulu/disertai dengan informasi maksud dan tujuan pemrosesan yang bersifat spesifik dan jelas *(informed consent)*.
- ☑ Persetujuan disampaikan langsung dan secara aktif (seperti meng-*click checkbox*) oleh pemilik data (bukan persetujuan diam-diam, otomatis, *preselected tick* atau *pre-checked checkbox*).
- ☑ Informasi yang menyertai persetujuan dibuat tidak ambigu dan sejalan dengan pengharapan pemilik data secara wajar.
- ☑ Persetujuan dapat ditarik kembali oleh pemilik data, kecuali diatur berbeda dalam regulasi PDP.
- ☑ Menampilkan formulir persetujuan secara terpisah dan tidak dipadukan dengan formulir/pernyataan lainnya.

1.2.1 Apakah pemrosesan data pribadi dilakukan sah secara hukum: adanya persetujuan yang sah dari pemilik data untuk tujuan tertentu yang telah disampaikan kepada pemilik data?



Contoh:

- PSE menampilkan jendela *pop-up* pada aplikasi/halaman webnya untuk meminta persetujuan dari pemilik data/pengguna serta menyampaikan informasi tujuan dan kegiatan pemrosesannya. *Pop-up* tersebut memuat opsi Ya dan Tidak *check boxes* dengan jelas tertulis bahwa 'saya memberikan persetujuan atas pemrosesan data pribadi tentang diri saya' atau 'saya mengerti bahwa data pribadi saya diproses' atau ekspresi sejenis lainnya.
- Persetujuan ambigu: menggunakan *Internet Cookies* yang terinstal dalam perangkat Pengguna dan PSE menggunakannya sebagai dasar persetujuan seterusnya dari pemilik data.
- Persetujuan yang tidak sah: persetujuan yang disampaikan secara tersembunyi (*silence*), *pre-ticked boxes*, atau nonaktif (*inactivity*).
- PSE memasang *browser plugin/extension* atau sejenisnya yang juga mengumpulkan data pribadi pengguna (seperti IP Address), PSE meminta persetujuan dari pemilik data dan juga menyampaikan beroperasinya *plugin* tersebut kepada pengguna.
- Penyediaan permainan interaktif elektronik memastikan penggunanya yang berada di bawah umur telah mendapatkan persetujuan dari orang tua atau walinya untuk menggunakan layanannya.
- PSE melakukan audit atau pemeriksaan *Internet Cookies* secara berkala (*a cookies audit*) untuk mengetahui kepatuhannya terhadap ketentuan PDP, khususnya keterpenuhan adanya persetujuan yang sah dari pemilik data.

1.2.2 Apakah pemrosesan data pribadi dilakukan sah secara hukum: pemenuhan kewajiban perjanjian dalam hal pemilik data menjadi salah satu pihak atau untuk memenuhi permintaan pemilik data pribadi pada saat akan melakukan perjanjian?

Layanan PSE hanya mungkin diselesaikan/diberikan kepada pelanggan jika pelanggan/pemilik data tersebut harus mengadakan kontrak/perjanjian dengan PSE (contoh, layanan hotel untuk mengetahui identitas pemesan, layanan *e-commerce* untuk mendapatkan alamat pengiriman, dan pembelian tiket perjalanan untuk identitas pemilik tiket, dan seterusnya). Dalam hal pemrosesan data dapat dilakukan tanpa adanya kontrak, maka pemrosesan data tidak dapat berdasarkan pada kontrak, tapi menggunakan dasar legalitas pemrosesan lainnya. Dasar pemrosesan ini tidak berlaku kepada situasi di mana tujuan pemrosesan bermanfaat bagi pemilik data (*useful but not objectively necessary*), tetapi harus benar-benar pengumpulan data pribadi adalah bagian esensial (integral) dengan pemenuhan suatu kontrak.

Praktik yang baik:

- ☑ PSE melakukan kajian/analisa untuk memastikan bahwa hanya dengan mengadakan perjanjian, maka layanannya dapat diberikan kepada pelanggan/pemilik data (layanan hotel dan *e-commerce)(objectively necessary for the performance of the contract*). Pertanyaan untuk membantu menentukan: apakah sifat dasar layanan PSE? Apa yang mendasari perlu adanya kontrak? Apa ketentuan pokok dalam kontrak? Apakah kebutuhan adanya kontrak juga sejalan dengan pengharapan pemilik data secara wajar?
- ☑ PSE menyediakan kontrak dengan bahasa yang mudah mengerti pengguna dan berkontrak dengan pengguna yang cakap secara hukum.
- ☑ Kontrak menyebutkan tujuan pemrosesan secara spesifik.
- ☑ PSE memastikan pemilik data mengetahui isi kontrak sebelum memberikan persetujuannya.

1.2.2 Apakah pemrosesan data pribadi dilakukan sah secara hukum: pemenuhan kewajiban perjanjian dalam hal pemilik data menjadi salah satu pihak atau untuk memenuhi permintaan pemilik data pribadi pada saat akan melakukan perjanjian?

Contoh:

- Penyedia jasa pembayaran secara digital kepada pengguna, maka jasa pembayaran tersebut tidak dapat dilakukan tanpa ada data pribadi untuk tujuan pembayaran/penagihan biaya sehingga dasar legalitas pemrosesan dapat menggunakan Pemenuhan Perjanjian/Kontrak dengan pengguna.
- PSE yaitu Pelaku usaha perdagangan melalui sistem elektronik **("PMSE")** mensyaratkan memasukkan alamat tempat tinggalnya. PSE tersebut dapat menggunakan kontrak untuk memproses alamat tersebut untuk keperluan pengiriman barang yang dibelinya, walaupun akhirnya dia membatalkan pembelian. Di lain pihak, Anda tidak dapat memakai dasar kontrak untuk menggunakan alamat tersebut dalam pemetaan preferensi pelanggan karena butuh persetujuan lain.
- Pelaku usaha PSME (PSE) menyusun profil pelanggan, yaitu kesukaan dan kebiasaan dari pelanggan berdasarkan riwayat pembelian/kunjungannya. Pemenuhan untuk kontrak jual beli (seperti pada contoh sebelumnya) tidak sesuai untuk dijadikan dasar pemrosesan untuk penyusun profil tersebut. Walaupun PSE tersebut menyebutkan dalam kontrak jual beli tersebut perihal penyusunan profil pelanggan, penyebutan tersebut tidak dapat menjadi fakta bahwa PSE memerlukan data pribadi untuk pemenuhan perjanjian. Jika PSE tetap ingin melakukan pemprofilan seperti tersebut, maka PSE perlu mendasarkan pada ketentuan syarat sah pemrosesan data yang lain.

1.2.2 Apakah pemrosesan data pribadi dilakukan sah secara hukum: pemenuhan kewajiban perjanjian dalam hal pemilik data menjadi salah satu pihak atau untuk memenuhi permintaan pemilik data pribadi pada saat akan melakukan perjanjian?

Contoh Sederhana Perbedaan Penggunaan Dasar Legalitas antara Adanya Persetujuan dengan Pemenuhan Kewajiban Perjanjian

Pemenuhan Perjanjian

- Pemenuhan kewajiban perjanjian dalam hal pemilik data pribadi merupakan salah satu pihak atau untuk memenuhi permintaan pemilik data pribadi pada saat akan melakukan perjanjian.
- Contoh: pemberian jasa yang melibatkan data pribadi yang tanpanya prestasi tidak dapat diberikan – *reserve hotel online*. Tanpa isi data pribadi atau apabila persetujuan ditarik saat kewajiban menyediakan hotel belum terlaksana, maka kewajiban dalam perjanjian tidak dapat dipenuhi. Kemudian pemenuhan *contract warranties (*contoh: jaminan pelaksanaan dari para pihak, atau jaminan pernyataan dalam kontrak adalah kebenaran*)*.

Adanya Persetujuan

- Persetujuan (*Consent*) : dalam hal persetujuan penggunaan data pribadi ditarik, layanan jasa tetap dapat diberikan. Misalnya: opsi personalisasi pada layanan *streaming* musik. Sewaktu kita tarik persetujuan jadi tidak ada *profile* tapi layanan *streaming* tetap jalan (tanpa menggunakan data pribadi).

Jika layanan streaming musik/video seperti tersebut, maka dasar legalitas yang digunakan adalah kewajiban adanya persetujuan/consent dari pemilik data. Tidak boleh menggunakan dasar legalitas pemenuhan kewajiban perjanjian sebagai dasar legalitas utama untuk pemrosesan tersebut.

1.2.3 Apakah pemrosesan data pribadi dilakukan sah secara hukum: pemenuhan kewajiban hukum dari pengendali data berdasarkan hukum?

Pemenuhan kewajiban hukum dari pengendali Data Pribadi sebagaimana ditugaskan dengan ketentuan peraturan perundang-undangan di Indonesia. Kewajiban hukum yang bersumber dari peraturan asing tidak berlaku sebagai dasar hukum yang sah untuk kegiatan pemrosesan data oleh PSE.

Praktik yang baik:

- ☑ PSE sebagai penyedia jasa dalam skema pengadaan pemerintah yang memuat ruang lingkup kegiatan pemrosesan data pribadi atas nama dan untuk kebutuhan pemberi pekerjaan (kementerian/lembaga) dalam rangka tugas penyelenggaraan negara (tugas pelayanan publik).
- ☑ PSE sebagai mitra kerja sama pemerintah berdasarkan kontrak untuk melakukan pemrosesan data pribadi sesuai dengan ruang lingkup pekerjaan yang diatur dalam kontrak antara PSE dengan instansi penyelenggara negara.
- ☑ PSE menerima penugasan khusus Pemerintah untuk melakukan pelayanan publik tertentu (seperti pelayanan kesehatan, perizinan, keimigrasian, transportasi, logistik, pendataan/sensus, dan sejenisnya) berdasarkan kontrak atau perintah peraturan perundang-undangan yang secara eksplisit menyebut dan menugaskan PSE tersebut.

1.2.3 Apakah pemrosesan data pribadi dilakukan sah secara hukum: pemenuhan kewajiban hukum dari pengendali data berdasarkan hukum?

Contoh:

- BUMN menerima penugasan khusus Pemerintah atau mendapatkan penunjukan langsung dari K/L berdasarkan keputusan pejabat publik untuk mengembangkan, mengoperasikan, dan mengelola Sistem Informasi Satu Data Vaksinasi Covid-19 yang sumber anggaran pelaksanaannya dibebankan pada APBN.
- Penyedia jasa sistem pembayaran atau badan usaha tertentu mendapatkan tugas dari pemerintah sebagai mitra instansi pengelola PNBP (Penerimaan negara bukan pajak) untuk menerima pembayaran dari pelayanan publik yang menjadi obyek PNBP (seperti pembayaran pemesanan nama untuk pendirian perusahaan atau pembayaran permohonan merek dagang melalui bank atau penyedia jasa pembayaran lainnya).

1.2.4 Apakah pemrosesan data pribadi dilakukan sah secara hukum: pelindungan kepentingan yang sah *(vital interest)* pemilik data?

Pemrosesan diperlukan untuk melindungi kepentingan vital subjek data atau orang perseorangan lainnya. Kepentingan vital ini harus menyangkut hidup dan matinya seseorang (atau kelangsungan hidupnya) secara langsung. Dasar legalitas ini berlaku pada keadaan darurat (atau Gawat Darurat) dan hanya digunakan dalam hal dasar legalitas pemrosesan lain tidak dapat diupayakan.

Praktik yang baik:

- ☑ Dalam hal PSE menggunakan *vital interest* sebagai dasar legalitas pemrosesannya, maka PSE membuat dokumentasi lengkap yang menjelaskan alasannya menggunakan kepentingan vital tersebut.
- ☑ Subyek data dalam keadaan *vital interest* tidak diperlukan lagi untuk memberikan persetujuan (secara fisik atau langsung).
- ☑ Apabila diminta otoritas yang berwenang, PSE memberikan dan menunjukkan pertanggung jawaban atas semua kegiatan pemrosesan data yang dilakukan berdasarkan *vital interest* disertai dengan dokumen pendukung yang terkait.
- ☑ PSE mengimplementasikan pengamanan akses ekstra terhadap data pribadi yang diproses berdasarkan dasar legalitas *vital interest,* seperti menerapkan metode enkripsi data, kontrol dan pembatasan akses kepada pihak yang tidak memilik tujuan yang memadai *(need-to-know basis),* dan mengadopsi standar teknis dan tata kelola *industry best practice*.

1.2.4 Apakah pemrosesan data pribadi dilakukan sah secara hukum: pelindungan kepentingan yang sah *(vital interest)* pemilik data?

Contoh:

- Seseorang dihantarkan ke IGD karena kecelakaan. Dalam praktiknya, pihak Rumah Sakit akan melakukan segala tindakan medis yang diperlukan untuk menolong orang tersebut, seperti mendapatkan rekam medisnya. PSE langsung melakukan pemrosesan data pribadi atas data keluarga korban untuk dihubungi keadaan darurat tersebut tanpa didasarkan pada persetujuan dari korban/pasien/subjek data.
- Pemrosesan data rekam medis pasien diatur, antara lain, dalam Peraturan Menteri Kesehatan tentang Rekam Medis. Pemanfaatan rekam medis dapat dipakai sebagai pemeliharaan kesehatan dan pengobatan pasien.
- Pemrosesan data pribadi terhadap data pasien yang tidak sadarkan diri.

1.2.5 Apakah pemrosesan data pribadi dilakukan sah secara hukum: pelaksanaan kewenangan pengendali data pribadi berdasarkan ketentuan peraturan perundang-undangan?

Kewenangan ini dimaknai sebagai kekuasaan badan atau pejabat pemerintahan (atau instansi penyelenggara negara lainnya) untuk bertindak dalam ranah hukum publik. Kewenangan ini sebagai dasar legalitas pemrosesan wajib berdasarkan peraturan perundang-undangan dan asas-asas umum pemerintahan yang baik (AUPB). Kewenangan ini diperoleh melalui atribusi UUD NRI 1945 atau undang-undang, delegasi dan/atau mandat dari pejabat atau badan yang lebih tinggi.

Praktik yang baik:

- ☑ PSE adalah badan dan/atau pejabat pemerintahan atau instansi penyelenggara negara yang memiliki kewenangan penggunaan kekuasaan negara. Tetapi, orang perseorangan atau badan hukum dapat ditunjuk/ditugaskan untuk melaksanakan sebagian kewenangan instansi penyelenggara negara berdasarkan kontrak.
- ☑ PSE memilik dasar kewenangan, yaitu dasar hukum dalam pengangkatan atau penetapan jabatan yang sesuai dengan kedudukan dan kewenangannya.
- ☑ Pengejawantahan kewenangan ini diwujudkan dalam tindakan dan/atau keputusan administrasi pemerintahan. Keputusan yaitu ketetapan tertulis dalam penyelenggaraan pemerintahan, sementara tindakan adalah perbuatan instansi penyelenggara negara untuk melakukan dan/atau tidak melakukan perbuatan kongkret dalam rangka penyelenggaraan pemerintahan.

1.2.5 Apakah pemrosesan data pribadi dilakukan sah secara hukum: pelaksanaan kewenangan pengendali data pribadi berdasarkan ketentuan peraturan perundang-undangan?

Praktik yang baik (lanjutan):

- ☑ Peraturan perundang-undangan yang hanya dapat dijadikan dasar adalah peraturan tertulis yang memuat norma hukum yang mengikat secara umum dan dibentuk atau ditetapkan oleh lembaga negara atau pejabat yang berwenang melalui prosedur yang ditetapkan dalam peraturan perundang-undangan.
- ☑ Dalam hal PSE adalah orang perorangan atau badan hukum yang terikat kontrak melaksanakan sebagian kewenangan, maka PSE wajib menyusun dokumentasi kegiatan pemrosesan data pribadi berdasarkan dasar legalitas ini.

Contoh:

- PSE adalah instansi penyelenggara negara yang kewenangan ditentukan dalam suatu undang-undang untuk memproseskan data pribadi, antara lain Undang-Undang Administrasi Kependudukan, Undang-Undang Telekomunikasi, Undang-Undang Kesehatan. Undang-Undang Perpajakan dan lain-lain.
- PSE selaku instansi penyelenggara negara mendelegasikan kewenangan kepada PSE yang juga berkedudukan sebagai instansi penyelenggara negara.
- PSE adalah orang perseorangan atau badan hukum yang mendapat tugas berdasarkan kontrak melaksanakan sebagian kewenangan dari instansi penyelenggara negara untuk pelayanan publik.
- Suatu badan layanan umum (BLU) pada Kementerian Keuangan RI, mengolah data pribadi penerima beasiswa. Kewenangan BLU dalam memproses data pribadi diperoleh dari ketentuan peraturan perundang-undangan tentang badan layanan umum, organisasi dan tata kelola BLU, dan prinsip efisiensi dan efektivitas penyelenggaraan pelayanan publik oleh BLU.

1.2.6 Apakah pemrosesan data pribadi dilakukan sah secara hukum: pemenuhan kewajiban pengendali Data Pribadi dalam pelayanan publik untuk kepentingan umum?

Pelayanan publik untuk kepentingan umum dapat dicermati dari sumber anggaran pelaksanaannya, yaitu bersumber atau melibatkan APBN/APBD maka dapat dimaknai sebagai pelayanan publik. Hal terkait lainnya adalah pelaksanaan pelayanan publik tersebut berasal dari kewenangan instansi penyelenggara negara sesuai ketentuan peraturan perundang-undangan, baik pelayanan publik yang dikenakan pungutan PNBP atau tidak. Adanya peraturan perundang-undangan yang memuat informasi bahwa pelayanan publik tertentu diselenggarakan demi kepentingan umum.

Praktik yang baik:

- ☑ Apabila diminta otoritas yang berwenang, PSE menunjukkan dasar hukum kewenangan atau tugasnya dalam pemrosesan data pribadi sebagai bentuk pelayanan publik untuk kepentingan umum.
- ☑ Dasar hukum tersebut adalah instrumen hukum yang berkedudukan lebih tinggi dan secara eksplisit membatasi hak pemilik data. Pembatasan ini dengan maksud semata-mata untuk menjamin pengakuan serta penghormatan atas hak dan kebebasan orang lain dan untuk memenuhi tuntutan yang adil sesuai ketentuan peraturan perundang-undangan.
- ☑ Dengan dasar legalitas ini, PSE berwenang menolak segala klaim atau permintaan penolakan pemrosesan data pribadi yang diajukan oleh pemilik data.
- ☑ PSE menyusun dokumentasi dan menerapkan pengamanan data sesuai dengan tingkat risiko pemrosesannya yang ditunjukkan dengan hasil penilaian mandiri dan hasil pemeriksaan auditor independen.

1.2.6 Apakah pemrosesan data pribadi dilakukan sah secara hukum: pemenuhan kewajiban pengendali Data Pribadi dalam pelayanan publik untuk kepentingan umum?

Contoh:

- PSE berkontrak dengan instansi penyelenggara negara dalam pengelolaan dan pengendalian data administrasi kependudukan atau data wajib pajak. Data Jenis data tersebut didapatkan dari semua pendudukan (atau warga masyarakat) Indonesia, tanpa terkecuali. Pemrosesan ini termasuk pelayanan publik untuk kepentingan umum.
- Otoritas pengatur dan pengawas sektor jasa keuangan meminta bank atau lembaga jasa keuangan lainnya menyerahkan laporan secara berkala yang dapat memuat informasi tentang debitur bermasalah atau debitur yang memiliki kredit dengan kolektibilitas macet. Pemrosesan ini termasuk pelayanan publik untuk kepentingan umum.
- Suatu instansi penyelenggara negara membuat daftar wajib pajak yang belum melunasi hutang pajak dan daftar dapat disediakan kepada publik. Penyusunan daftar tersebut adalah sah secara hukum sepanjang (i) berdasarkan peraturan perundang-undangan; (ii) adanya pemenuhan setiap prinsip PDP sebagaimana apabila berlaku. Penyusunan daftar tersebut untuk pengawasan dan penegakan hukum dibidang perpajakan.

1.2.7 Apakah pemrosesan data pribadi dilakukan sah secara hukum: pemenuhan kepentingan yang sah lainnya dari pengendali data pribadi dan/atau pemilik data?

Pemenuhan kepentingan yang sah lainnya dengan memperhatikan tujuan, kebutuhan, dan keseimbangan kepentingan Pengendali Data Pribadi dan hak Pemilik Data Pribadi. Dasar legalitas ini tidak dapat digunakan secara langsung, tapi harus ada pengkajian yang memadai terlebih dahulu (*legitimate interests assessment*) dan hanya untuk keadaan kasuistik. Dasar legal ini tidak untuk kepentingan pengendali atau pemilik data yang bersifat spekulatif atau baru terjadi di masa depan, tetapi kepentingan aktual. Kepentingan yang dimaksud ini harus sejalan dengan ketentuan peraturan perundang-undangan di Indonesia (bukan kepentingan yang bersumber dari hukum luar negeri).

Praktik yang baik:

- ☑ Sebelum menggunakan dasar legalitas ini, PSE menyusun kajian tentang kepentingan yang sah dimaksud untuk menganalisis pemenuhan terhadap (i) kespesifikan kepentingan yang sah dan dasar hukumnya; (ii) adanya kebutuhan aktual terhadap tujuan pemrosesan data pribadi disertai dengan upaya pelindungan hak pemilik data yang memadai *(balance-of-interest test);* dan (iii) kepentingan yang sah ini bersifat aktual, bukan kepentingan di masa mendatang.
- ☑ Penyelenggara negara tidak dapat menggunakan dasar legalitas ini secara langsung, kecuali didasarkan pada dasar hukum yang sah.

1.2.7 Apakah pemrosesan data pribadi dilakukan sah secara hukum: pemenuhan kepentingan yang sah lainnya dari pengendali data pribadi dan/atau pemilik data?

Praktik yang baik (lanjutan):

- ☑ PSE mengedepankan pengharapan pelindungan data yang wajar dari pemilik data *(reasonable expectation)* dalam kegiatan pemrosesan dengan dasar legalitas ini.
- ☑ PSE menunjukkan bahwa ia memiliki kepentingan yang sah dan bersifat lebih memaksa untuk dipenuhi sehingga sah secara hukum membatasi hak pemilik data.
- ☑ Walaupun data pribadi tersedia secara publik, PSE tidak dapat menggunakannya sebagai alasan pemrosesan data yang dilakukan berdasarkan kepentingan yang sah dari pengendali data.
- ☑ Dalam hal menggunakan dasar legalitas ini, PSE menerapkan prinsip transparansi pemrosesan data pribadi, menjustifikasi kesesuaian tujuan pemrosesan dibandingkan dengan tujuan awal pemrosesan data pribadi, memberitahu tujuan kepentingan yang sah kepada pemilik data, dan menghindari adanya kerugian yang nyata kepada pemilik data.

1.2.7 Apakah pemrosesan data pribadi dilakukan sah secara hukum: pemenuhan kepentingan yang sah lainnya dari pengendali data pribadi dan/atau pemilik data?

Contoh:

- Pemrosesan data pribadi dalam rangka penerapan strategi anti *fraud* (seperti kecurangan, penipuan, penggelapan aset, pembocoran informasi, tindak pidana perbankan) oleh bank atau lembaga jasa keuangan lainnya. Tindakan pemrosesan ini meliputi pencegahan, deteksi, investasi, pelaporan, sanksi, pemantauan, evaluasi dan tindak lanjut.
- Pemrosesan data untuk tujuan *direct marketing*. Akan tetapi PSE wajib menghentikan permintaan pengiriman materi promosi kepada pemilik data yang menyatakan menolak *(unsubscribe)* dengan atau tanpa disertai alasan.
- Pemrosesan data untuk tujuan administrasi bisnis yang dilakukan (atau saling dipertukarkan) oleh perusahaan dengan anak atau induk perusahaannya. Jenis data meliputi data karyawan dan/atau pelanggan.
- Pemrosesan data untuk tujuan pengamanan pemanfaatan jaringan telekomunikasi dan/atau informasi elektronik.
- Pemrosesan data pribadi karyawan untuk melihat kinerjanya, yang mana hal ini kepentingan yang sah dari pengusaha khususnya membayar upah kepada pekerja sesuai dengan kesepakatan yang ditetapkan berdasarkan satuan waktu dan/atau hasil (capaian). PSE tetap perlu memastikan pemrosesan tersebut tidak menghalangi hak karyawan.
- Tujuan pemrosesan yang perlu dilakukan pengkajian kasuistik: kebebasan pers, menyatakan pendapat di muka umum, kampanye politik atau sosial, mengajukan gugatan hukum/penyelesaian sengketa di luar pengadilan, perlindungan keselamatan dan kesehatan kerja, *whistleblowing system,* tujuan statistik, riset/penelitian ilmiah (*market research*).

A. PRINSIP-PRINSIP PEMROSESAN DATA PRIBADI

BAGIAN 02

Relevansi Tujuan Pemrosesan dan Perolehan Data Pribadi

2.1 Apakah pengumpulan data pribadi dilakukan secara terbatas dan spesifik?

Pemrosesan perlu sesedikit mungkin menggunakan data pribadi sepanjang yang hanya dibutuhkan untuk tujuan pemrosesan yang spesifik. Kecukupan data pribadi ditentukan oleh PSE sewajar mungkin berdasarkan kajian atau penilaiannya. Data pribadi yang tidak relevan dengan tujuan pemrosesan, tidak perlu dikumpulkan atau dimusnahkan dari kegiatan pemrosesan.

Praktik yang baik:

- ☑ PSE melakukan analisis mendalam untuk memeriksa sejauh mana jenis, volume, dan kategori data pribadi yang dibutuhkan untuk mencapai tujuan pemrosesannya. Analisis ini menjawab apakah pengumpulan bermacam data pribadi sudah cukup terbatas, spesifik, dan benar-benar diperlukan untuk mencapai tujuan pemrosesannya.
- ☑ Dalam hal PSE mengetahui bahwa ada cara atau upaya lain mencapai tujuan pemrosesannya tanpa mengumpulkan data pribadi, maka upaya lain tersebut yang digunakan.
- ☑ PSE menentukan variabel dan acuan untuk mengetahui kecukupan data pribadi yang akan diperoleh.
- ☑ PSE melakukan verifikasi terhadap setiap tujuan pemrosesannya, khususnya mengetahui tujuan mana saja yang dapat dicapai tanpa memproses data pribadi. Proses verifikasi ini dilakukan sebelum kegiatan pemrosesan.
- ☑ PSE melakukan anomisasi (*anonymization*) atau memusnahkan data pribadi yang tidak relevan dengan tujuan pemrosesannya. Data ini diubah sedemikian rupa sehingga tidak dapat lagi mengidentifikasi pemilik data.
- ☑ Apabila diminta otoritas yang berwenang, PSE menunjukkan bahwa setiap data pribadi yang diperoleh sangat relevan dengan tujuan pemrosesannya.

2.1 Apakah pengumpulan data pribadi dilakukan secara terbatas dan spesifik?

Contoh:

- Penyelenggara *Fintech Lending* membuat daftar debitur bermasalah dan/atau macet yang di dalamnya memuat data pribadi debitur. Data pribadi ini hanya terbatas dan spesifik untuk tujuan penagihan tunggakan debitur, antara lain data pribadi tentang nomor kontak, alamat debitur dan jumlah hutang jatuh tempo. PSE ini menjustifikasi data pribadi di cukup terbatas dan spesifik untuk memenuhi tujuan pemrosesannya data. Setelah tujuan terpenuhi data pribadi tersebut dimusnahkan oleh PSE setelah melewati kewajiban jangka waktu retensi data sesuai regulasi.
- Rekrutmen calon pekerja pemantau keamanan sistem elektronik mensyaratkan calon pekerja melengkapi data pribadi yang hanya dibutuhkan untuk tujuan pekerjaan tersebut. Umumnya proses ini tidak membutuhkan data rekam medis karena dapat dijustifikasi tidak relevan dengan tujuan pemrosesan.
- Toko buku *online* mengumpulkan data pribadi pembelinya, antara lain alamat rumah, nomor kontak, dan informasi pembayaran. Akan tetapi, apabila toko ini menjual *e-book* (buku digital), maka alamat pembeli tidak dibutuhkan untuk tujuan pemrosesan ini sehingga pemilik data tidak perlu diminta mengisi alamat rumahnya.

2.2 Apakah data pribadi yang Anda peroleh sesuai dengan tujuan pemrosesan Data Pribadi?

Tujuan pemrosesan data pribadi menentukan apa saja data pribadi yang dibutuhkan untuk memenuhi tujuan tersebut. Apabila ditentukan tujuan pemrosesan lanjutan, maka tujuan ini masih sesuai dengan tujuan awal saat data pribadi dikumpulkan.

Praktik yang baik:

- ☑ PSE melakukan *review* secara berkala untuk mengetahui apakah kegiatan pemrosesannya (pengumpulan) data pribadi telah atau masih sesuai dengan tujuan pemrosesannya.
- ☑ PSE menganalisis kesesuaian tujuan awal pengumpulan data pribadi dengan tujuan lanjutannya, antara lain, kaitan/hubungan tujuan awal dengan tujuan lanjutan pemrosesannya, ruang lingkup tujuan pemrosesan (termasuk dampak/risiko kepada pemilik data), upaya pengendalian dan pelindungan data tersebut (seperti enkripsi data dan *pseudonymisation*).
- ☑ PSE menerima dan mempertimbangkan pendapat/masukan dari pemilik data mengenai pengharapan pelindungan data pribadinya, kelengkapan dan kejelasan penjelasan tujuan pengumpulan data pribadi.
- ☑ PSE mengubah tujuan pemrosesan lanjutan sesuai dengan pengharapan yang wajar dari pemilik data mengenai pelindungan dan pemanfaatan datanya, termasuk tindakan meminta persetujuan kembali kepada mereka apabila dasar legalitas tersebut yang berlaku.
- ☑ PSE menerapkan kehati-hatian dalam pengungkapan data pribadi kepada pihak ketiga karena pengungkapan ini belum tentu sesuai dengan tujuan pengumpulan data pribadi.

2.2 Apakah data pribadi yang Anda peroleh sesuai dengan tujuan pemrosesan Data Pribadi?

Contoh:

- PSE mengumpulkan data pribadi pengguna portal webnya, antara lain, melalui *Internet cookies*. Sebelum pengguna membaca konten portal webnya, PSE menampilkan informasi tentang tujuan penggunaan *cookies* tersebut dan meminta persetujuan kepada pemilik data/pengunjung. Tindakan pengumpulan data ini sejalan dengan tujuan pemrosesannya.
- PSE mengungkapkan data pribadi kepada otoritas pengawasan keselamatan dan kesehatan kerja. Tujuan pengungkapan ini masih memenuhi kesesuaian tujuan pemrosesan data pribadi karena didasarkan pada regulasi.
- PSE media sosial daring memberi opsi kepada penggunanya untuk menentukan *postingan*/konten mana saja yang dapat dibaca teman-temannya atau hanya untuk dirinya sendiri. Akan tetapi, pengembang aplikasi pihak ketiga yang berada pada media sosial PSE tersebut masih dapat mengakses konten tersebut walaupun pengguna telah mengatur bahwa konten tertentu hanya untuk dirinya *(only me)*. Ini contoh pemrosesan lanjutan oleh pengembang tersebut tidak sejalan dengan tujuan awal PSE tersebut mengumpulkan data pribadi.

A. PRINSIP-PRINSIP PEMROSESAN DATA PRIBADI

BAGIAN 03

Jaminan Hak Pemilik Data Pribadi

3.1 Apakah Anda menjamin hak Pemilik Data untuk merahasiakan Data Pribadinya?

Pemilik data berhak atas kerahasiaan data pribadinya sejak data tersebut diperoleh, dikumpulkan, diolah, dan dianalisis, kecuali ditentukan lain sesuai dengan ketentuan peraturan perundang-undangan. Yang dimaksud dengan "kerahasiaan" adalah sesuai dengan konsep hukum tentang kerahasiaan (*confidentiality*) atas informasi dan komunikasi secara elektronik.

Praktik yang baik:

- ☑ Hak atas kerahasiaan data pribadi diimplementasikan berdasarkan prinsip: tujuan yang sah, persetujuan yang sah, mematuhi peraturan perundang-undangan yang berlaku, penggunaan informasi rahasia seminimum yang diperlukan, pihak yang mengumpulkan dan memproses data rahasia wajib melaksanakan bertanggung jawabnya.
- ☑ Perlu adanya metode atau prosedur untuk menjamin kerahasiaan integritas data, catatan, dan informasi terkait transaksi elektronik.
- ☑ Jika terjadi kegagalan pelindungan rahasia data pribadi dalam Sistem Elektronik yang dikelola, maka PSE wajib memberitahukan secara tertulis kepada Pemilik Data Pribadi paling lambat 14 (empat belas) hari sejak diketahui adanya kegagalan tersebut.
- ☑ PSE dapat menentukan level kerahasiaan data pribadi berdasarkan tingkat risiko ketika data tersebut diungkapkan: berdampak rendah, sedang dan tinggi.

Contoh:

- PSE wajib meminta persetujuan pemilik data untuk kasus-kasus yang berkaitan dengan kejahatan seksual.
- Akuntan wajib merahasiakan data tentang pendapatan, pengeluaran, dan status pajak klien mereka.
- PSE mengadakan perjanjian kerahasiaan/NDA dengan karyawan, vendor, dan mitra bisnisnya dalam pemrosesan data pribadi.

3.2 Apakah terdapat akses atau kesempatan bagi Pemilik Data Pribadi untuk mengubah dan/atau memperbarui Data Pribadinya?

PSE wajib memberikan akses atau kesempatan kepada Pemilik Data Pribadi untuk mengubah atau memperbarui Data Pribadinya tanpa mengganggu sistem pengelolaan Data Pribadi, kecuali ditentukan lain oleh ketentuan peraturan perundang-undangan. Pengubahan atau pembaharuan data berhubungan dengan jaminan akurasi data.

Praktik yang baik:

- ☑ PermenKominfo 20/2016, dan perubahannya dari waktu ke waktu, tidak menentukan prosedur permintaan pengubahan/ pembaruan data pribadi yang sah. Secara praktik, hal ini dapat dilakukan secara lisan maupun tertulis. Sepanjang Pemilik Data meragukan keakuratan data tersebut dan meminta untuk diganti/diperbarui, maka PSE wajib mengambil langkah-langkah untuk melakukan perbaikan dan melengkapi data.
- ☑ PSE wajib mengubah atau memperbaharui data sesuai dengan permintaan pemilik data berdasarkan periode tertentu yang sesuai (*reasonable time*). Lazimnya paling lama 1 bulan sejak permintaan dibuat.
- ☑ Permintaan pemilik data berpotensi eksesif (berlebihan atau di luar kewajaran) jika: mengulangi substansi permintaan sebelumnya; atau tumpang tindih dengan permintaan lain.

3.2 Apakah terdapat akses atau kesempatan bagi Pemilik Data Pribadi untuk mengubah dan/atau memperbarui Data Pribadinya?

Contoh:

- Pemilik data berkeyakinan data mereka tidak akurat dan berulang kali meminta diganti. Namun PSE telah mengecek dan beranggapan data tersebut akurat. Pemilik data terus mengajukan permohonan dengan alasan yang tidak berdasar. Oleh karena itu PSE wajib mengemukakan alasan tidak mengubah data tersebut, memberikan hak kepada pemilik data untuk menindaklanjuti kepada otoritas yang berwenang.

3.3 Apakah Anda menyediakan akses atau kesempatan bagi Pemilik Data Pribadi untuk memperoleh Data Pribadi yang pernah diserahkan?

Pemilik Data berhak mendapatkan akses dan salinan historis data pribadi, data yang telah diproses PSE, maupun data tambahan lainnya (contoh: tujuan pemrosesan data, pihak-pihak yang dapat mengakses personal data, berapa lama data tersebut disimpan, informasi keamanan data pribadinya jika ditransfer ke luar negeri, dan lain-lain) sesuai peraturan perundang-undangan yang berlaku.

Praktik yang baik:

- ☑ Meskipun permintaan akses data pribadi dapat dilakukan secara lisan, namun praktik terbaik biasanya dilakukan secara tertulis untuk mengantisipasi jika terjadi konflik di kemudian hari.
- ☑ Jika pemilik data meminta banyak akses data, maka PSE berhak meminta klarifikasi tentang tujuan permintaan dan memberikan akses data yang relevan sesuai dengan permintaan/ tujuan tersebut.
- ☑ Data yang diminta dapat diberikan dalam bentuk tertulis, elektronik atau secara lisan.
- ☑ Pemberian akses wajib diberikan dalam waktu yang wajar (biasanya 1 bulan sejak permintaan diajukan) dan dapat diperpanjang bergantung pada kompleksitas permintaan data.
- ☑ PSE dapat menolak permintaan akses pemilik data dengan memberikan alasan penolakan, memberikan hak kepada pemilik data untuk menempuh jalur lain agar permintaan aksesnya dapat diperoleh.

3.3 Apakah Anda menyediakan akses atau kesempatan bagi Pemilik Data Pribadi untuk memperoleh Data Pribadi yang pernah diserahkan?

Contoh:

- PSE menyediakan layanan media sosial berbasis *online* di mana individu dapat bertukar pesan dan gambar. Pemilik data meminta akses data pribadi mereka dan untuk memverifikasi data pribadi apa yang menjadi perhatian mereka yang diproses oleh PSE. PSE wajib mengonfirmasi bahwa sedang memproses data pribadi yang berkaitan dengan pemilik data dan memberikan salinannya (seperti nama, detail kontak, pesan, dan gambar yang dipertukarkan). PSE juga wajib memberi informasi tentang pemrosesan – biasanya ada dalam pemberitahuan privasi layanan PSE.

3.4 Apakah Anda melakukan pengambilan keputusan yang hanya didasarkan pada pemrosesan secara otomatis terkait profil seseorang (*profiling*)?

Di Indonesia belum diatur perihal PSE yang pengambilan keputusan hanya berdasarkan pemrosesan secara otomatis terkait profil seseorang. Hal ini masih menjadi wacana dalam RUU PDP, di mana Pemilik Data Pribadi berhak untuk mengajukan keberatan atas tindakan pengambilan keputusan yang hanya didasarkan pada pemrosesan secara otomatis terkait profil seseorang (*profiling*).

Praktik yang baik:

- ☑ Pengambilan keputusan hanya didasarkan pada pemrosesan otomatis yang tidak melibatkan manusia sangat dibatasi (namun tidak dilarang).
- ☑ Kondisi yang diizinkan: (i) diperlukan untuk melakukan kesepakatan kontrak kinerja antara perusahaan dan individu; (ii) Berdasarkan ketentuan peraturan perundang-undangan (misalnya untuk menghindari penghindaran pajak); atau (iii) berdasarkan persetujuan eksplisit individu.
- ☑ PSE yang mengambil keputusan hanya didasarkan pada pemrosesan secara otomatis terkait profil seseorang wajib: (i) memberikan informasi spesifik kepada individu tentang pemrosesan; (ii) PSE wajib mengambil melakukan upaya untuk mencegah kesalahan, bias dan diskriminasi; dan (iii) memberikan hak kepada individu untuk mengajukan keberatan dan meminta peninjauan kembali atas keputusan tersebut.
- ☑ Dalam hal pengambilan keputusan dengan pemrosesan otomatis, PSE wajib menerapkan prinsip proporsional dan transparan, dengan memastikan individu: (i) mendapat hak peninjauan ulang yang dilakukan oleh pejabat yang berwenang; (ii) memberikan kesempatan kepada individu untuk mengungkapkan sudut pandangnya; dan (iii) memperoleh penjelasan tentang keputusan tersebut dan menyatakan keberatannya.

3.4 Apakah Anda melakukan pengambilan keputusan yang hanya didasarkan pada pemrosesan secara otomatis terkait profil seseorang (*profiling*)?

Praktik yang baik (lanjutan):

- ☑ PSE menerapkan langkah-langkah teknis dan organisasi yang tepat, sehingga dapat memperbaiki ketidakakuratan dan meminimalkan risiko kesalahan; mengamankan data pribadi dengan cara yang sebanding dengan risiko terhadap

Contoh:

- Contoh kasus pengambilan keputusan yang **hanya** didasarkan pada pemrosesan secara otomatis terkait *profiling*:
  Gaji pekerja terkait produktivitas mereka dipantau secara otomatis. Keputusan tentang berapa banyak gaji yang diterima pekerja untuk setiap *shift* mereka bekerja dibuat secara otomatis dengan mengacu pada data yang dikumpulkan tentang produktivitas mereka.
- Contoh kasus pengambilan keputusan yang **bukan hanya** didasarkan pada pemrosesan secara otomatis terkait *profiling*:
  A ingin meminjam uang ke bank, di mana A diminta memasukkan data pribadi dan algoritma bank memberi keputusan apakah akan memberi pinjaman atau tidak, serta menentukan tingkat bunga yang disarankan. Jika A merasa keberatan dengan hasil algoritma tersebut, maka dapat meminta keputusan ditinjau ulang oleh pejabat bank yang berwenang.

3.5 Apabila pada nomor 3.4, Anda menjawab Ya, apakah Anda memiliki mekanisme bagi Pemilik Data untuk mengajukan keberatan atas tindakan pengambilan keputusan yang hanya didasarkan pada pemrosesan secara otomatis terkait profil seseorang (*profiling*)?

PSE wajib mengakomodir permintaan tertulis Pemilik Data Pribadi yang mengajukan keberatan atas tindakan profiling. Profil dalam hal ini termasuk namun tidak terbatas pada riwayat pekerjaan, kondisi ekonomi, kesehatan, preferensi pribadi, minat, konsistensi tindakan, perilaku, lokasi atau pergerakan Pemilik Data Pribadi secara elektronik.

Praktik yang baik:

- ☑ PSE melakukan profiling sesuai dengan ketentuan yang disebutkan pada nomor 3.4
- ☑ PSE menyediakan sarana untuk dapat menerima pengajuan keberatan Pemilik Data Pribadi yang menginginkan profiling atas data pribadinya dihentikan.
- ☑ PSE menginformasikan kepada Pemilik Data Pribadi mengenai sarana pengajuan keberatan tersebut beserta dengan prosedur pemrosesan penghentian profiling.
- ☑ PSE mengimplementasikan ketentuan terkait prinsip transparansi dan hak mendapatkan akses ke pemilik data sebelum melakukan kegiatan profiling. Dalam hal PSE menggunakan fitur profiling, maka PSE menyampaikan kepada pemilik data bahwa profil pemilik data akan disusun berdasarkan *online behaviour*-nya dalam platform atau website yang diselenggarakan/digunakan PSE sehingga memungkinkan PSE atau mitranya dapat membuat profil pemilik data untuk tujuan, misalnya, *targeted advertising*. Sebelum profiling dilakukan, PSE menyediakan narahubung kepada pemilik data dalam hal ia mengajukan hak mendapatkan aksesnya terhadap data profil/hasil profiling yang dilakukan PSE dengan atau tanpa mitra/vendornya.
- ☑ PSE melakukan analisis dampak pemrosesan profiling terhadap risiko dan kerugian yang berpotensi berdampak pada pemilik data.

3.5 Apabila pada nomor 3.4, Anda menjawab Ya, apakah Anda memiliki mekanisme bagi Pemilik Data untuk mengajukan keberatan atas tindakan pengambilan keputusan yang hanya didasarkan pada pemrosesan secara otomatis terkait profil seseorang (*profiling*)?

Contoh:

- Pemilik Data Pribadi dapat mengajukan penghentian pemrosesan data pribadinya terkait dengan penerimaan iklan yang dipersonalisasi atas profil yang bersangkutan. Pada saat Pemilik Data Pribadi mengajukan keberatan terhadap hal ini, maka keputusan penayangan iklan sepihak berdasarkan profiling atas Pemilik Data Pribadi harus dihentikan.
- PSE menjual produk fesyen yang ditujukan untuk pemilik data kategori pria yang mana PSE hendak mempromosikannya kepada pria yang berusia antara 30 sampai 40 tahun. PSE melakukan profiling dan kemudian mempromosikan produk fesyen antara pukul 17:00 sampai 20:00 WIB. Sebelum promosi tersebut, PSE bersama vendor/mitranya (termasuk platform *social media*) telah menentukan kriteria pemilik data dan jenis data yang akan dikumpulkan untuk menyusun profil pemilik data. Terhadap pemrosesan profiling ini, PSE menyampaikan informasi kepada pemilik data (sebelum kegiatan profiling), antara lain, identitas dan narahubung PSE, tujuan pemrosesan, kategori data pribadi, setiap pihak yang menjadi penerima data pribadi, kegiatan transfer data (jika ada), jangka waktu penyimpanan data, jaminan dan sarana mengajukan komplain dan hak mendapatkan akses, sumber perolehan data pribadi, dan gambaran cara kerja profiling (khususnya logika algoritmanya, signifikansi serta keluaran yang diharapkan dari profiling tersebut).

A. PRINSIP-PRINSIP PEMROSESAN DATA PRIBADI

BAGIAN 04

Keakuratan Data Pribadi

4.1 Apakah Anda telah memastikan bahwa Data Pribadi diproses secara akurat, lengkap, tidak menyesatkan, dan mutakhir?

PSE wajib memastikan data pribadi diproses secara:

(i) akurat (artinya data pribadi diambil tanpa adanya ketidakakuratan, seperti salah mencatat persetujuan subjek data yang menerima informasi pemasaran untuk produk lain dari Pengguna Data);

(ii) lengkap (artinya informasi terkait Subjek Data belum dihilangkan, misalnya yang dapat menyebabkan Pengguna Data membuat keputusan yang tidak menguntungkan berkaitan dengan permohonan layanan bagi Subjek Data);

(iii) tidak menyesatkan (artinya data pribadi yang diproses oleh Pengguna Data tidak boleh - karena kesalahan, kelalaian, kealpaan dan lain-lain. - mengakibatkan informasi status Subjek Data yang tidak akurat atau salah); dan

(iv) mutakhir (artinya data pribadi harus mencerminkan informasi terkini yang diberikan oleh subjek data).

Praktik yang baik:

- ☑ Akurasi data berfokus pada aspek bentuk dan isi data. Kepastian akurasi data dapat dilakukan dengan melakukan audit kualitas data, SDM yang ahli, perbaikan otomatis pada data, dan fokus pada data tertentu untuk diperbaiki, bukan keseluruhan data.
- ☑ Data lengkap mencakup (namun tidak terbatas) informasi identitas PSE, kebijakan dan prosedur pelindungan privasi dan pengamanan sistem, perjanjian tingkat layanan, ketentuan penggunaan layanan oleh pengguna, serta pernyataan jaminan atas barang dan/jasa yang ditawarkan.

4.1 Apakah Anda telah memastikan bahwa Data Pribadi diproses secara akurat, lengkap, tidak menyesatkan, dan mutakhir?

Praktik yang baik (lanjutan):

- ☑ Untuk menghindari kesesatan data, dapat dilakukan dengan: mendokumentasi setiap data, mendokumentasi sumber data, mengambil langkah yang diperlukan untuk memastikan keakuratan data, dan mengidentifikasi berbagai hambatan dalam mendapatkan data yang akurat/ benar.
- ☑ Pemutakhiran data dilakukan berdasarkan tujuan pemrosesan data. Jika PSE membutuhkan data yang mengandalkan kemutakhiran data, maka data harus selalu diperbaharui. Namun jika data disimpan hanya untuk keperluan statistik, histori, atau penelitian, maka melakukan pemutakhiran justru merusak tujuan pemrosesan data.

Contoh:

- Di Indonesia, tanggal menggunakan format DD/MM/YYYY, sedangkan apabila PSE juga memiliki *data base* di EU, format yang digunakan MM/DD/YY. Jika 09/10/2020 diproses datanya, mana yang paling akurat 10 September atau 9 Oktober? Bentuk data dapat menjadi persoalan karena kurangnya standarisasi.
- Berkaitan dengan kemutakhiran data, kesalahan diagnosis medis tetap didokumentasikan karena menjadi bagian dari rekam medis pasien bahkan setelah diagnosis diperbaiki. Hal ini bertujuan menjelaskan riwayat tindakan medis yang diberikan kepada pasien, atau untuk masalah kesehatan lainnya.

A. PRINSIP-PRINSIP PEMROSESAN DATA PRIBADI

BAGIAN 05

Langkah Pengamanan Data Pribadi

5.1 Apakah Anda memiliki prosedur dan mekanisme keamanan data terhadap pemrosesan Data Pribadi?

Pengamanan data adalah hal utama dalam mencapai kepatuhan terhadap salah satu prinsip PDP. PSE wajib memiliki dan menjalankan prosedur dan sarana untuk pengamanan data pribadi dalam sistem elektronik yang dikuasai atau dikelolanya berdasarkan asas risiko untuk menghindari gangguan, kegagalan dan kerugian. Gangguan adalah setiap tindakan yang bersifat destruktif yang mengakibatkan sistem elektronik tidak bekerja sebagaimana mestinya. Kegagalan menjadikan fungsi esensial sistem elektronik tidak beroperasi, sedangkan kerugian menimbulkan akibat hukum bagi pemilik data baik secara materiil dan immateriil, antara lain, *identity fraud,* pemalsuan tagihan dan pembayaran, korban penipuan, tercemarnya aib seseorang, tidak terpenuhinya hak asasinya, dan promosi yang intrusif/mengganggu.

Praktik yang baik:

- ☑ PSE menyediakan rekam jejak audit terhadap seluruh kegiatan pemrosesan data pribadi. Rekam jejak ini dapat diminta sewaktu-waktu oleh otoritas yang berwenang.
- ☑ Dalam hal terjadi kegagalan/gangguan sistem yang berdampak serius, PSE wajib mengamankan data pribadi dan segera melaporkan dalam kesempatan pertama kepada otoritas yang berwenang dan segera tanpa menunda-nunda memberitahukan kepada pemilik data atas dampak serius kebocoran data pribadi guna pemilik data dapat mengantisipasi risiko dari peristiwa tersebut.
- ☑ PSE memasang instrumen pengamanan dan tata kelola untuk menjaga kerahasiaan data pribadi yang wajib dirahasiakan menurut peraturan perundang-undangan.
- ☑ PSE melakukan edukasi keamanan data kepada pengguna/pengelola data pribadi, serta senantiasa memperbaharui aplikasi atau instrumen pengamanan sistem setiap waktu *(on-going security update)*.

5.1 Apakah Anda memiliki prosedur dan mekanisme keamanan data terhadap pemrosesan Data Pribadi?

Praktik yang baik (lanjutan):

- ☑ PSE mengadopsi standar teknis dan tata kelola keamanan data pribadi, antara lain, ISO Manajemen Keamanan Informasi, ISO Teknik Keamanan Data, dan *industry best practice*.
- ☑ PSE melakukan evaluasi pengamanan data secara berkala dan meningkatkan kelayakan keamanan data berbasis pada risiko pemrosesannya.

Contoh:

- PSE melakukan evaluasi untuk menganalisis kategori sistem elektroniknya, yaitu sistem elektronik strategis, tinggi dan rendah menggunakan "format penelitian mandiri kategorisasi sistem elektronik" sebagaimana diatur dalam Peraturan Badan Siber dan Sandi Negara ("**BSSN**") mengenai sistem pengamanan dalam penyelenggaraan sistem elektronik. Hasil evaluasi ini dilaporkan kepada otoritas tersebut.
- PSE menyusun dan menerapkan aturan internal pengamanan data, memetakan para penanggung jawabnya, membatasi akses ke data pribadi, mengaudit/memeriksa para vendornya untuk mengetahui kepatuhan pengamanan data, membuat rencana pemulihan bencana dan rencana penanganan kebocoran data, mengadakan kontrak kerahasiaan data dengan para pihak yang mengakses data pribadi, mengikuti pelatihan keamanan data secara berkala, membuat *password* dan proses autentifikasi lain yang lebih aman, membuat rekam-rekam jejak audit (siapa saja yang mengakses dan dapat memodifikasi data pribadi), menerapkan enkripsi data dan anonimisasi, memasang dan memperbaharui aplikasi *Internet security/anti-virus,* memonitor dan mengamankan *traffic* jaringan telekomunikasi, membuat rekam cadang elektronik (*backup*) secara berkala, mengamankan *mobile/portable devices,* melakukan *penetration testing,* memastikan keandalan sistem pemusnahan data, dan memasang pengamanan fisik terhadap setiap komponen sistem elektronik.

5.2 Apakah Anda menggunakan jasa pihak ketiga dalam pemrosesan data?

Yang dimaksud dengan pihak ketiga yakni individu atau badan hukum yang memproses data pribadi atas nama atau untuk kepentingan PSE. Pemrosesan data meliputi perolehan dan pengumpulan, pengolahan dan penganalisisan, perbaikan dan pembaruan, penampilan, pengumuman, transfer, penyebarluasan, atau pengungkapan, dan/atau penghapusan atau pemusnahan Data Pribadi. Jika PSE Lingkup Publik menggunakan layanan pihak ketiga, maka wajib melakukan klasifikasi data sesuai risiko yang ditimbulkan.

Praktik yang baik:

- ☑ Substansi kontrak antara PSE dan pihak ketiga setidaknya memuat: (i) ruang lingkup pemrosesan data yang dirumuskan secara spesifik dan durasi pemrosesan; (ii) sifat dan tujuan pemrosesan; (iii) Jenis data pribadi dan kategori subjek data (pelanggan, karyawan, mitra kerjasama, vendor, kreditur, dan lain-lain); dan (iv) hak dan kewajiban Pihak ketiga/prosesor dan PSE/pengendali data.
- ☑ Jika sistem pemrosesan dan jejak audit merupakan tanggung jawab pihak ketiga, maka proses jejak audit tersebut harus sesuai dengan standar yang ditetapkan oleh PSE.
- ☑ Penunjukan jasa pihak ketiga umumnya mempertimbangkan: (i) jaminan pelindungan data yang optimal; (ii) dapat memberikan keyakinan dan kepuasan sistem pemrosesan data kepada PSE, mencakup penilaian risiko kasus per kasus, dengan mempertimbangkan sifat, ruang lingkup, konteks, dan tujuan pemrosesan, serta risiko pelindungan data; (iii) Pengetahuan dan keahlian jasa pihak ketiga (misal keahlian teknis terkait tindakan keamanan; keandalan prosesor; SDM); (iv) sertifikasi.

5.2 Apakah Anda menggunakan jasa pihak ketiga dalam pemrosesan data?

Praktik yang baik (lanjutan):

- ☑ Pihak ketiga/prosesor hanya memproses data pribadi sepanjang ada instruksi tertulis dari PSE/pengendali data. Prosesor menjamin dan memastikan setiap pihak/karyawan yang mengakses data pribadi wajib merahasiakan informasi data tersebut. Prosesor mengadopsi tata kelola dan implementasi keamanan data berdasarkan standar teknis tertentu. Prosesor dilarang mengalihkan kewajibannya kepada pihak ketiga lain kecuali terlebih dahulu ada persetujuan tertulis dari PSE/pengendali. Prosesor wajib bekerjasama dan melaksanakan permintaan PSE/pengendali terkait pemenuhan hak pemilik data dan pemberitahuan gangguan keamanan data atau sistem. Jika terjadi pengakhiran kontrak, berdasarkan kebijakan dari pengendali/PSE, prosesor memusnahkan setiap salinan atau memindahkan data pribadi kepada sistem PSE. Prosesor wajib menyediakan informasi dan asistensi untuk pengawasan kepatuhan ketentuan PDP dan/atau audit.

Contoh:

- PSE menggunakan jasa perusahaan A untuk mengelola pembayaran gaji karyawannya. PSE memberikan instruksi yang jelas tentang siapa yang harus membayar, berapa jumlahnya, pada tanggal berapa, oleh bank mana, berapa lama data akan disimpan, data apa yang harus diungkapkan kepada otoritas pajak, dan lain-lain. Dalam hal ini, pemrosesan data dilakukan untuk tujuan PSE membayar gaji kepada karyawannya dan pihak ketiga tidak boleh menggunakan data untuk tujuan apa pun. Cara pihak ketiga harus melakukan pemrosesan telah diuraikan dengan jelas dan ketat. Namun pihak ketiga dapat memutuskan hal-hal terperinci tertentu seputar pemrosesan seperti perangkat lunak mana yang akan digunakan, bagaimana mendistribusikan akses dalam organisasinya sendiri, dan lain-lain. Hal ini tidak mengubah perannya sebagai pemroses selama pihak ketiga tidak melampaui kewenangan atau tujuan pemrosesan yang ditentukan oleh PSE.

5.3 Dalam hal penggunaan jasa pihak ketiga, apakah Anda memiliki perjanjian tertulis yang berisikan ketentuan Pelindungan Data Pribadi?

PSE wajib membuat perjanjian tertulis, baik dalam bentuk kontrak atau bentuk lainnya yang diperbolehkan oleh peraturan perundang-undangan dengan pihak ketiga berkaitan dengan hal-hal pokok pemrosesan data yang akan menjadi otoritas dari pihak ketiga. Pemrosesan yang dilakukan oleh pihak ketiga wajib tunduk pada ketentuan peraturan perundang-undangan tentang pelindungan data pribadi.

Praktik yang baik:

- ☑ Perjanjian tertulis dapat disusun oleh salah satu pihak. Berdasarkan faktor: posisi para pihak di pasar dan kedudukannya dalam kontrak, keahlian teknis, serta akses ke jasa hukum advokat. Misalnya, beberapa penyedia jasa cenderung menetapkan syarat dan ketentuan standar, yang mencakup perjanjian pemrosesan data.
- ☑ Pihak ketiga wajib menerapkan langkah-langkah teknis dan organisasi yang sesuai untuk memastikan keamanan data pribadi, termasuk melindungi dari kerusakan atau kehilangan yang tidak disengaja atau melanggar hukum, perubahan, pengungkapan atau akses yang tidak sah.
- ☑ Pihak ketiga wajib membantu PSE untuk mematuhi ketentuan PDP, yang mencakup keamanan pemrosesan data, menginformasikan terhadap gangguan/kebocoran data, dan penilaian terhadap dampak pemrosesan data.
- ☑ Pada pengakhiran kontrak, berdasarkan kebijakan dari PSE, pihak ketiga wajib menghapus data pribadi yang sudah tidak terpakai untuk memastikan pelindungan terhadap data pribadi.
- ☑ Pihak ketiga wajib memberikan semua informasi yang diperlukan PSE untuk meningkatkan kepatuhan dalam PDP dan pihak ketiga terbuka terhadap audit kepatuhan ketentuan PDP yang dilakukan oleh PSE.

5.3 Dalam hal penggunaan jasa pihak ketiga, apakah Anda memiliki perjanjian tertulis yang berisikan ketentuan Pelindungan Data Pribadi?

Contoh:

- Jasa Pihak Ketiga yang menangani periklanan, selama kontrak berlangsung, pihak ketiga mendapatkan akses ke data pribadi pelanggan, misal, nomor telepon, alamat domisili atau alamat email. Dalam kontrak, diperjanjikan bahwa pihak ketiga hanya boleh menggunakan data pribadi pelanggan hanya untuk keperluan periklanan perusahaan tersebut.
- Untuk menghindari kehilangan data, PSE menggunakan jasa penyedia layanan penyimpanan cadangan data. Karena pihak ketiga tersebut memiliki akses ke data yang disimpan, perjanjian tertulis berisi ketentuan pelindungan data pribadi wajib ditandatangani.

5.4 Apakah Anda memiliki aturan internal terkait hal pengelolaan Data Pribadi?

Setiap PSE harus mempunyai aturan internal terkait pelindungan Data Pribadi untuk melaksanakan pemrosesan Data Pribadi yang sesuai dengan ketentuan peraturan perundang-undangan. Aturan internal ini memuat ketentuan yang berlaku sejak pengumpulan sampai pemusnahan data pribadi.

Praktik yang baik:

- ☑ PSE memiliki kebijakan pemrosesan data pribadi untuk dapat dipatuhi oleh setiap karyawan perusahaan pada saat melakukan pemrosesan data pribadi. Apabila pemrosesan melibatkan vendor atau mitra kerja sama, maka aturan dan kebijakan pemrosesan wajib disampaikan kepada mereka *(vendor policy)* dan diawasi kepatuhannya oleh PSE (pengendali data).
- ☑ Aturan internal yang dimaksud harus mempertimbangkan aspek penerapan teknologi, sumber daya manusia, metode, dan biaya, serta peraturan perundang-undangan yang berlaku.
- ☑ Aturan internal pengelolaan data pribadi mengatur paling sedikit tentang:
  - Edukasi kepada seluruh pihak terkait dalam pemrosesan data pribadi yang dilakukan secara berkala. Ruang lingkup edukasi, antara lain, hak, kewajiban, dan tanggung jawab para pihak tersebut, serta prosedur pengajuan komplain.
  - Pejabat yang berwenang dalam pengambilan keputusan terkait pemrosesan data pribadi dan pengiriman data pribadi kepada pihak ketiga atau pemilik data.
  - Persyaratan atau kondisi pemanfaatan data pribadi (contoh harus adanya perintah dari pejabat yang berwenang dari PSE, dan sesuai dengan ketentuan peraturan perundang-undangan).

5.4 Apakah Anda memiliki aturan internal terkait hal pengelolaan Data Pribadi?

- Aturan internal pengelolaan data pribadi mengatur paling sedikit tentang (lanjutan):
  - Upaya pengamanan terhadap akses ke lokasi penyimpanan data dan media penyimpanan data (contoh adanya otorisasi akses masuk dan log akses).
  - Tata kelola fitur otomatis untuk akses ke data pribadi yang dipasang oleh PSE, dan pemeriksaan secara berkala atas beroperasinya fitur otomatis tersebut sebagaimana mestinya.
  - Kegiatan dokumentasi pemrosesan data, serta dokumentasi segala bentuk pengungkapan data.

Contoh:

- Suatu kantor hukum memiliki kebijakan pemrosesan data pribadi yang disosialisasikan dan disetujui setiap karyawan pada saat penerimaan pegawai dikarenakan banyaknya aspek pemrosesan data pribadi dalam pelaksanaan pemberian layanan oleh kantor hukum tersebut. Dengan demikian apabila karyawan kantor hukum terkait melakukan pemrosesan data pribadi, karyawan yang bersangkutan telah memahami sifat kerahasiaan dan cara PSE melakukan pemrosesan data pribadi. Kebijakan internal ini berbeda dengan kebijakan privasi yang disampaikan oleh kantor hukum bersangkutan untuk kliennya.
- PSE menyusun aturan internal pemrosesan data pribadi dengan melibatkan unit bisnis yang memproses data, antara lain, *human resources, ethics, marketing, business development, finance, legal, security, risk, governance,* dan *research and development*.
- PSE membentuk tim internal pengawasan dan pengendalian PDP pada perusahaannya (*privacy team)*

5.5 Apakah Anda melakukan sosialisasi kepada seluruh pegawai mengenai aturan internal terkait pengelolaan data pribadi?

Terkait dengan kewajiban menyusun aturan internal untuk PSE, maka untuk dapat melaksanakan aturan internal dengan baik maka PSE dapat melakukan sosialisasi aturan internal yang dimaksud.

Praktik yang baik:

- ☑ Sosialisasi dilakukan secara berkala dan melalui berbagai media agar seluruh pegawai mengetahui bagaimana cara pemrosesan Data Pribadi beserta perubahan-perubahan yang relevan atas aturan internal tersebut.

- ☑ PSE menunjuk satu divisi yang bertanggung jawab memastikan kepatuhan terhadap aturan internal dan jalannya sosialisasi kepada seluruh pegawai.

5.5 Apakah Anda melakukan sosialisasi kepada seluruh pegawai mengenai aturan internal terkait pengelolaan data pribadi?

Contoh:

- Pengiriman email kepada seluruh pegawai yang dilanjutkan rapat sosialisasi adanya aturan internal perlindungan data pribadi yang dilakukan setiap 6 bulan sekali dan setiap terdapat perubahan terhadap aturan internal yang terkait.
- PSE melakukan sosialisasi aturan internal terkait pengelolaan dan pelindungan data pribadi, antara lain, melalui forum sosialisasi formal maupun informal, seperti diklat PDP (berbayar atau gratis), *online learning,* poster, buku saku, lokakarya, acara kuis/permainan interaktif, slogan, *roadshow, newsletters,* komik, *voicemail broadcast,* pamflet, *digital lobby signage,* mengundang narasumber, dan sebagainya. Sosialisasi ini mencakup sanksi, tanggung jawab jika ada karyawan melakukan pelanggaran aturan internal tersebut, mekanisme penilaian kepatuhan yang diterapkan, prosedur penanganan insiden gangguan atau kegagalan PDP, dan lain-lain. PSE mengalokasi anggaran yang memadai untuk kegiatan sosialisasi ini. Penyelenggaraan sosialisasi tersebut didokumentasikan oleh PSE, antara lain, jumlah dan frekuensi aktivitas sosialisasi, jumlah karyawan dan mitra yang berpartisipasi, metode sosialisasi, persentase ketercapaian target sosialisasi, hasil dari sosialisasi, serta jumlah peserta yang membutuhkan sosialisasi lanjutan atau pelatihan khusus.

5.6 Apakah Anda memiliki program internal terkait peningkatan kesadaran pelindungan Data Pribadi, seperti pelatihan, lokakarya, atau lainnya?

Dengan adanya aturan internal pelindungan data pribadi dalam entitas PSE, dalam rangka pencegahan kegagalan pelindungan Data Pribadi (misalnya penyebarluasan tanpa izin data pribadi individual), diperlukan pelatihan internal berkala untuk dapat mengingatkan setiap karyawan yang terlibat dalam pemrosesan data pribadi.

Praktik yang baik:

- ☑ PSE mengadakan pelatihan internal secara berkala dan berkelanjutan untuk mensosialisasikan dan mengingatkan kembali penerapan kebijakan aturan internal pelindungan data pribadi.
- ☑ PSE mengikutsertakan pengenalan aturan internal pelindungan data pribadi pada program perkenalan karyawan baru.
- ☑ PSE memfasilitasi atau mengikutsertakan DPO-nya dalam pelatihan peningkatan kesadaran dan/atau keahlian atau kompetensi PDP.
- ☑ PSE memfasilitasi atau mengikutsertakan karyawannya dan semua pihak yang terkait dengan pemrosesan data pribadi dalam pelatihan keamanan data dan penanganan insiden keamanan *(cyber security and incident response)*.
- ☑ Program pelatihan yang akan digunakan perlu dianalisis kelayakan dan kualitas pelatihannya dengan memperhatikan materi muatan dan cara pelatihan, adanya sertifikasi dan ujian pelatihan, status pengakuan lembaga pelatihan tersebut, dan kegiatan pelatihan berskala internasional.

5.6 Apakah Anda memiliki program internal terkait peningkatan kesadaran pelindungan Data Pribadi, seperti pelatihan, lokakarya, atau lainnya?

Contoh:

- Sosialisasi aturan internal pelindungan data pribadi dimulai dari *induction program* untuk karyawan baru.
- PSE mengalokasikan anggaran perusahaannya untuk mengikutsertakan karyawannya dalam pelatihan DPO dan/atau pelatihan PDP.
- PSE memilih lembaga pelatihan yang bereputasi internasional dan memiliki ahli yang mumpuni terkait PDP.
- PSE menyelenggarakan pelatihan yang menarik, seperti gamifikasi (*gamification*) atau mengadakan kontes antar rekan untuk memotivasi mereka agar lebih melindungi data pribadinya dan informasi rahasia perusahaan.
- PSE secara berkala mengeluarkan pamflet, poster, audio visual konten, atau media kampanye *awareness-raising* lainnya untuk memperkuat pemahaman pengguna data pribadi atas ketentuan PDP.
- PSE mengajak para vendor dan mitra bisnisnya kegiatan pelatihan implementasi PDP.

5.7 Apakah Anda memiliki pegawai/karyawan yang secara khusus bertanggung jawab atas hal-hal yang terkait dengan pelindungan Data Pribadi yang Anda kelola?

PSE yang melakukan pengelolaan data pribadi wajib menyediakan narahubung (*contact person*) yang mudah dihubungi oleh Pemilik Data Pribadi terkait pengelolaan Data Pribadinya. PSE perlu menyampaikan kontak narahubung tersebut kepada pemilik data. Selain narahubung PDP tersebut, PSE wajib menyediakan kepada pengguna sistem elektronik informasi tentang telepon pusat pengaduan.

Praktik yang baik:

- ☑ PSE mencantumkan nomor kontak yang dapat dihubungi oleh pengguna sistem elektronik pada sistem elektronik yang digunakan.
- ☑ Apabila tidak terdapat nomor yang dapat dihubungi, dapat disertakan cara lain untuk dapat mengkontak narahubung (*chat, email, eform*).
- ☑ Narahubung PDP berupa DPO atau pejabat/petugas yang melaksanakan fungsi PDP. Istilah lainnya, *chief privacy officer (CPO)*, *chief compliance officer (CCO)*, dan *chief information officer (CIO)*.
- ☑ Pemrosesan data untuk pelayanan publik, pemrosesan data pribadi sensitif, atau pemrosesan data pribadi yang secara rutin dan berskala besar (dalam arti jumlah data, jangka waktu, kategori, dan wilayah cakupan pemrosesan) adalah kegiatan utama PSE, maka PSE disarankan memiliki DPO dan mengadakan analisis dampak dan risiko pemrosesannya. Kegiatan/layanan utama PSE artinya aktivitas operasional PSE dalam memberikan layanan utamanya kepada pelanggan, seperti pemberian fasilitas pelayanan kesehatan yang memproses data pribadi pasien.

5.7 Apakah Anda memiliki pegawai/karyawan yang secara khusus bertanggung jawab atas hal-hal yang terkait dengan pelindungan Data Pribadi yang Anda kelola?

Praktik yang baik (lanjutan):

- ☑ DPO bertugas antara lain (i) menganalisis kepatuhan PSE terhadap ketentuan PDP berdasarkan regulasi; (ii) melakukan manajemen risiko pemrosesan data pribadi, yaitu identifikasi jenis risiko, penilaian, pengukuran, pemantauan, dan pengendaliannya; (iii) melakukan komunikasi dan kerja sama dengan otoritas yang berwenang; (iv) melakukan pengendalian PDP berbasis risiko; dan (v) dokumentasi pemrosesan data pribadi. DPO memberikan pendapat dan solusi bagaimana mencapai kepatuhan ketentuan PDP berdasarkan keahlian profesional dan independensinya.

Contoh:

- Penyedia aplikasi *marketplace* menyediakan fitur *chat*, email, nomor telepon pada aplikasinya untuk dapat dihubungi oleh pengguna aplikasi.
- Pemrosesan data berskala besar adalah penyelenggaraan satu data vaksin, kartu perjalanan angkutan umum, asuransi jiwa dan kesehatan, pemrosesan oleh mesin pencari Internet, pemrosesan oleh operator jasa telekomunikasi, dan sejenisnya.
- PSE mengadakan rekrutmen DPO yang memiliki kompetensi, yaitu memahami hukum dan implementasi PDP, mengerti aspek keamanan data, mengerti aspek-aspek kegiatan pemrosesan, memiliki kemampuan berkomunikasi yang baik, dan miliki komitmen tinggi menyelenggarakan program peningkatan kesadaran PDP serta pengembangan diri.

A. PRINSIP-PRINSIP PEMROSESAN DATA PRIBADI

BAGIAN 06

Informasi Pemrosesan Data Pribadi

6.1 Apakah Anda telah mendokumentasikan semua kegiatan pemrosesan dalam rangka pelindungan Data Pribadi?

PSE wajib menerapkan rekam jejak audit terhadap seluruh kegiatan pemrosesan data pribadi dalam sistem elektronik yang dikelolanya. Kewajiban ini adalah bagian dari implementasi tata kelola sistem elektronik yang baik dan akuntabel (*IT Governance*). *IT Governance* mencakup proses perencanaan, pengimplementasian, pengoperasian, pemeliharaan, dan pendokumentasian.

Praktik yang baik:

- ☑ PSE mekanisme rekam jejak audit yang meliputi;
  - Memelihara log transaksi sesuai dengan kebijakan retensi data penyelenggara berdasarkan peraturan perundang-undangan (antara lain, PermenKominfo 20/2016 dan perubahannya dari waktu ke waktu);
  - Memberikan notifikasi kepada konsumen apabila suatu transaksi berhasil dilakukan;
  - Memastikan tersedianya fungsi jejak audit untuk dapat mendeteksi usaha dan/atau terjadinya penyusupan yang harus *di-review* atau dievaluasi secara berkala; dan
  - Dalam hal sistem pemrosesan dan jejak audit merupakan tanggung jawab pihak ketiga, maka proses jejak audit tersebut harus sesuai dengan standar yang ditetapkan oleh PSE.
- ☑ Apabila diminta otoritas yang berwenang, PSE memberikan rekam jejak audit untuk keperluan pengawasan, penegakan hukum pidana, penyelesaian sengketa, verifikasi, pengujian, dan pemeriksaan untuk keperluan mitigasi atau penanganan tanggap darurat (*incident response)* sesuai dengan ketentuan peraturan perundang-undangan (antara lain, PermenKominfo 5/2020 dan perubahannya dari waktu ke waktu).

6.1 Apakah Anda telah mendokumentasikan semua kegiatan pemrosesan dalam rangka pelindungan Data Pribadi?

Contoh:

- PSE menerapkan prosedur dan sarana dokumentasi/perekaman seluruh kegiatan pemrosesan data pribadi yang meliputi: (a) identitas dan kontak PSE; (b) tujuan pemrosesan; (c) deskripsi kategori pemilik data (jika ada) dan jenis data pribadi yang diproses; (d) pihak yang menerima pengungkapan data pribadi; (e) kegiatan transfer data ke luar negeri; (f) sarana dan prosedur pemusnahan data; dan (g) prosedur dan sarana pengamanan data pribadi.
- PSE menguraikan kegiatan berdasarkan sejumlah pertanyaan: Daftar pertanyaan tersebut, seperti: "mengapa Anda perlu menggunakan data pribadi?", "Data pribadi siapa yang Anda kelola?", "Data pribadi dan informasi apa saja yang Anda kumpulkan dari mereka?", "Kepada siapa Anda mengirimkan atau membagikan data tersebut?", "Berapa lama Anda menyimpan data tersebut?", "Bagaimana Anda melindungi data tersebut?" "Unit bisnis mana saja yang memproses data pribadi dan jenis data apa yang dikumpulkannya?"
- PSE mendokumentasikan semua dokumen terkait PDP: kebijakan privasi, manual penyimpanan data, dokumen dalam rangka keamanan data, prosedur pemanfaatan data, perjanjian dengan vendor/prosesor data, perjanjian transfer data, dan seterusnya. Informasi dalam setiap dokumen diperbaharui secara berkala.

Contoh Dokumen Pemrosesan (1)

Contoh Format Dokumentasi Pemrosesan

PSE / PENGENDALI DATA PRIBADI

Identitas Pengendali	Pejabat atau Petugas yang Melaksanakan Fungsi Data Pribadi (DPO)	Perwakilan (*Representative*) *(pihak – individu atau badan hukum di Indonesi – yang ditunjuk pengendali atau prosesor data secara tertulis untuk mewakili pengendali atau prosesor data terkait kewajibannya masing-masing berdasarkan regulasi PDP. BIsa jadi pengendali sendiri)*
Nama	Nama	Nama
Alamat	Alamat	Alamat
Email	Email	Email
Telp	Telp	Telp
	Organisasi DPO (jika DPO eksternal)	

Rincian kegiatan pemrosesan				**Tujuan pemrosesan data**	**Data Pribadi yang bersifat spesifik**
Nama kegiatan pemrosesan	**No pemrosesan**	**Tanggal pembuatan dokumentasi**	**Tanggal dokumentasi diperbaharui**		**Ya/Tidak**
[contoh] Tata kelola pengupahan	*1-xx-xx-xx*	*[Tanggal bulan tahun]*	*[Tanggal bulan tahun]*	*[Contoh: Manajemen pengupahan, penghitungan besaran upah, perhitungan besaran bagian upah yang dipotong untuk jaminan sosial]*	*Tidak*
[pemrosesan lain]					

Deskripsi tindakan pemrosesan	
Nama tindakan pemrosesan	
No. pemrosesan	
Data pembuatan pemrosesan	
Pembaharuan pemrosesan	
Tujuan pemrosesan	
Tujuan utama	
Tujuan pendukung 1	
Tujuan pendukung 2	
Tujuan pendukung 3	
Tujuan pendukung 4	
Tujuan pendukung 5	

Para Pihak	**Nama**	**Alamat**	**Negara**	**No. telp**	**Email**
Pengendali data					
DPO					
Organisasi DPO (jika DPO eksternal)					
Perwakilan					
Pengendali data bersama (*joint controllers*)					

Contoh Dokumen Pemrosesan (2)

Jenis data pribadi	Deskripsi	Jangka waktu penyimpanan
Nama lengkap, jenis kelamin, kewarganegaraan, agama, identitas lain		
Informasi kehidupan privasi (kebiasaan/gaya hidup, hub-keadaan keluarga, dan seterusnya)		
Informasi keadaan keuangan/ekonomi (pendapatan, situasi keuangan, data perpajakan, dan seterusnya		
Data koneksitas (alamat IP Internet, *logs*, kata sandi, dan seterusnya)		
Data lokasi (pergerakan, GPS, GSM, dan seterusnya)		
[*sebut data pribadi yang bersifat umum lainnya*]		
Data pribadi yang bersifat spesifik	**Deskripsi**	**Jangka waktu penyimpanan**
Data dan informasi kesehatan		
Data biometrik		
Data genetika		
Kehidupan/orientasi seksual		
Pandangan politik		
Catatan kejahatan		
Data anak		
Data keuangan pribadi		
Data suku/ras		
Data keikutsertaan dalam organisasi masyarakat		
Data pribadi yang bersifat spesifik	**Deskripsi**	**Jangka waktu penyimpanan**
Data dan informasi kesehatan		
Data biometrik		
Data genetika		
Kehidupan/orientasi seksual		
Pandangan politik		
Catatan kejahatan		
Data anak		
Data keuangan pribadi		
Data suku/ras		
Data keikutsertaan dalam organisasi masyarakat		

Penerima Data (*Recipient*)	Kategori Penerima	Detail
Penerima data 1	*[contoh: bagian internal perusahaan yang memproses data yang ditransfer, prosesor, penerima data di luar negeri atau organisasi internasional, institusi atau mitra komersial, ATAU lain-lain spesifikkan]*	
Penerima data 2		
Penerima data 3		
Tingkatan pengamanan	**Teknik pengamanan**	**Detail**
Tindakan pengamanan 1	*[contoh: rekam jejak audit, software protection apps, pencadangan data, enkripsi data, kendali akses data, pengendalian oleh prosesor data, sistem pencegahan dan penanggulangan lain, seperti anti-virus, anti-spamming, firewall, instrusion detection, pervention system, pengelolaan sistem manajemen keamanan informasi, dan lain-lain*	
Tindakan pengamanan 2		
Tindakan pengamanan 3		
Kategori subjek/pemilik data	**Deskripsi**	**Detail**
Kategori 1	*[contoh: karyawan, penyedia jasa internal, pelanggan, penyedia/supplier, penyedia jasa, prospek pelanggan, pendaftar, ATAU lain-lain rincikan]*	
Kategori 2		
Kategori 3		

Transfer Data Internasional	Penerima	Negara	Dasar Melakukan Transfer	Nama & Tautan Internet ke Dokumen
Penerima data 1			*[tentukan pilihan, contoh: tingkatan PDP yang setara/kesetaraan PDP, perjanjian antar pengendali data, perjanjian internasional, Binding Corporate Rules (jika berlaku), kode perilaku asosiasi, sertifikasi, ketentuan lain (jika ada)]*	
Penerima data 2				
Penerima data 3				

6.2 Apakah Anda telah memberitahukan kepada Pemilik Data Pribadi mengenai aktivitas pemrosesan Data Pribadi yang mencakup kejelasan identitas, dasar kepentingan hukum, tujuan permintaan dan penggunaan Data Pribadi?

PSE wajib menyampaikan informasi (*duty to inform*) kepada pemilik data pribadi paling sedikit mengenai, identitas PSE, obyek yang ditransaksikan, kelaikan atau keamanan sistem elektronik, tata cara penggunaan perangkat (*terms of use),* syarat kontrak, prosedur mencapai kesepakatan, jaminan privasi dan PDP *(privacy policy, data protection notice, fair processing notice),* serta nomor telepon pusat pengaduan. Kewajiban ini dimaksud untuk melindungi kepentingan penggunaan sistem elektronik, termasuk pemilik data pribadi.

Informasi yang Disampaikan PSE kepada Pemilik Data

Informasi yang disampaikan	Data pribadi yang didapatkan langsung dari pemilik data	Data pribadi yang didapatkan dari sumber lain
Nama dan kontak PSE	✓	✓
Nama dan kontak perwakilan/kuasa PSE	✓	✓
Kontak DPO: petugas yang berfungsi PDP	✓	✓
Tujuan pemrosesan	✓	✓
Dasar syarat sah pemrosesan	✓	✓
Kepentingan yang sah lainnya	✓	✓
Kategori data pribadi (umum atau spesifik)		✓
Penerima atau kategori penerima (*recipients*)	✓	✓
Detail transfer data internasional	✓	✓
Durasi penyimpanan data	✓	✓
Hak yang dimiliki/tersedia bagi subjek data	✓	✓
Hak untuk mencabut persetujuan pemrosesan	✓	✓
Hak mengajukan pengaduan ke Kominfo	✓	✓
Sumber perolehan data pribadi		✓
Keterangan apakah terdapat kewajiban berdasarkan peraturan perundang-undangan atau perjanjian yang berlaku bagi pemilik data untuk menyampaikan data pribadinya.	✓	
Penjelasan penerapan teknologi pengambilan keputusan secara otomatis, termasuk profiling oleh PSE	✓	✓

6.2 Apakah Anda telah memberitahukan kepada Pemilik Data Pribadi mengenai aktivitas pemrosesan Data Pribadi yang mencakup kejelasan identitas, dasar kepentingan hukum, tujuan permintaan dan penggunaan Data Pribadi?

Praktik yang baik:

- ☑ PSE menyampaikan kepada pemilik data atau kuasanya (jika pemilik data adalah anak-anak) pada saat perolehan data pribadi atau mereka mengakses portal web yang terpasang *Internet cookies*. Informasi yang disampaikan dapat dibuat dua versi, yaitu versi pendek/ringkas dan versi panjang dalam kebijakan pribadi. Informasi yang disampaikan sebagaimana tabel pada halaman sebelumnya.
- ☑ Informasi pemrosesan data kepada pemilik data wajib disampaikan oleh PSE secara ringkas, mudah dimengerti, mudah diakses, menggunakan bahasa lugas, dan sejelas mungkin menyesuaikan usia pemilik data (anak-anak dan dewasa).
- ☑ Jika PSE mendapatkan data pribadi dari sumber lain (bukan dari pemilik data), maka batas waktu memberi tahu kepada pemilik data adalah satu bulan atau paling lambat saat data pribadi diungkapkan kepada pihak lain.

Contoh:

- PSE mengirim email yang berisi tautan Internet ke portal webnya menginformasikan kegiatan pengumpulan dan pemrosesan data pribadi.
- PSE mengirim email atas perubahan kebijakan privasinya.
- PSE menempatkan simbol/*icon "baca selengkapnya"* atas kegiatan pemrosesan. Upaya lain selain *icon,* adalah, *just-in-time notification, pop-ups, voice alerts, mobile device gesture*.
- PSE menyampaikan tujuan pemrosesan dengan spesifik, contohnya, "Kami menyimpan data histori transaksi pelanggan dan menggunakan sebagai basis rekomendasi produk lain yang menjadi ketertarikan pelanggan", dibandingkan hanya menyampaikan "Kami menggunakan data pribadi pelanggan untuk meningkatkan layanan kami ".

6.3 Apakah Anda memiliki mekanisme pemberitahuan secara tertulis kepada Pemilik Data Pribadi jika terjadi kegagalan dalam pelindungan Data Pribadi?

Kewajiban ini bagian dari implementasi sarana dan prosedur pengamanan data pribadi. Dalam hal terjadi gangguan atau kegagalan PDP dalam sistem elektronik yang dikendalikan PSE yang berdampak serius, maka PSE wajib segera melaporkannya kepada otoritas yang berwenang pada kesempatan pertama dan kepada pemilik data paling lambat 14 hari sejak ganggaun diketahui.

Praktik yang baik:

- ☑ Dalam hal terjadi kegagalan kerahasiaan data pribadi atau pelindungannya, maka PSE memberitahu kepada pemilik data dengan ketentuan:
  - Menyampaikan penyebab terjadinya gangguan/kegagalan PDP;
  - Menyampaikannya secara elektronik kepada pemilik data sebagaimana mestinya;
  - Memastikan pemberitahuan diterima oleh pemilik data; dan
  - Pemberitahuan paling lambat 14 hari sejak diketahuinya adanya kegagalan PDP.
- ☑ *ISO/IEC 27040 defines a data breach as: compromise of security that leads to the accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or access to protected data transmitted, stored or otherwise processed.*
- ☑ Kewajiban pemberitahuan berlaku sejak diketahui (*aware*) adanya kegagalan atau gangguan PDP. Diketahuinya kegagalan bergantung pada keyakinan PSE yang sewajarnya dimengerti ahli (*reasonable degree of certainty*). Hal yang ditekankan utama adalah tindakan PSE menginvestigasi gangguan tersebut.

6.3 Apakah Anda memiliki mekanisme pemberitahuan secara tertulis kepada Pemilik Data Pribadi jika terjadi kegagalan dalam pelindungan Data Pribadi?

Contoh:

- Kegagalan PDP dapat berupa kehilangan akses secara permanen atau sementara (kecuali *planned system maintenance)*, atau data tentang informasi individu yang disimpan dalam perangkat elektronik akibat dari kejadian pencurian data atau gangguan sistem elektronik. Kegagalan juga dapat terjadi jika data pribadi yang dikelola terkena enkripsi oleh *ransomware,* atau kunci de-enkripsi yang dimiliki PSE tidak berada lagi bawah kendali/kuasanya.
- Akibat dari kegagalan atau gangguan PDP dapat berupa kerugian materil dan immateriil kepada pemilik data: kehilangan kontrol atas data pribadi, membatasi pelaksanaan hak PDP individu, diskriminasi, pencurian identitas atau penipuan, kerugian finansial, mengungkapkan inisial data pribadi yang memungkinkan teridentifikasi pemilik datanya, kerugian reputasi, dan terungkapnya informasi rahasianya yang sebelumnya dilindungi berdasarkan kewajiban rahasia jabatan/profesi. Akibat ini berdampak secara ekonomi dan sosial terhadap pemilik data.
- PSE menganalisis dampak gangguan atau kegagalan PDP kepada pemilik data, dan apa bila berdampak serius, segera tanpa menunda-nunda memberitahu kepada pemilik data dan memastikan mereka mendapatkan pemberitahuan tersebut.
- PSE memasang teknologi atau aplikasi yang memonitor (*detect, address, and report*) insiden kegagalan atau gangguan PDP, dan bekerjasama dengan vendor lain untuk mengatasi atau memulihkan dampak dari gangguan tersebut. PSE memiliki dan mengimplementasikan *incident response plan*.

6.4 Apakah Anda menyediakan kanal aduan yang dapat digunakan oleh Pemilik Data Pribadi untuk melaporkan dampak terhadap kegagalan pelindungan Data Pribadi?

PSE wajib menjamin ketersediaan sarana dan layanan pengaduan, dengan setidaknya menginformasikan nomor telepon pusat pengaduan kepada Pemilik Data Pribadi. Keberadaan berbagai sarana pengaduan merupakan cara untuk mengukur efektivitas sistem pencegahan pelanggaran data pribadi, sekaligus meningkatkan keandalan pelindungan data.

Praktik yang baik:

- ☑ Kanal aduan ini dapat digunakan oleh pemilik data pribadi, mitra PSE, karyawan, dan pihak-pihak terkait lainnya terkait kegagalan pelindungan data pribadi.
- ☑ Pemilik data pribadi yang melapor wajib bertindak atas dasar itikad baik, jujur, dan tidak merugikan kepentingan pihak ketiga.
- ☑ Dalam menerima laporan pengaduan, PSE wajib menjamin kerahasiaan informasi pengaduan dan identitas pengadu.
- ☑ PSE sebaiknya memiliki dokumen tata cara pengaduan dan bagaimana merespon pengaduan tersebut, baik aduan yang mengacu pada kegagalan pelindungan di masa lalu, saat ini, maupun potensi kegagalan pelindungan data pribadi di masa depan.
- ☑ Seluruh pengaduan wajib mencantumkan setidaknya tanggal, fakta-fakta yang dilaporkan dan perkiraan tanggal kejadian. Pengadu dapat melampirkan berbagai dokumen yang relevan dengan kasus kegagalan pelindungan data pribadi.
- ☑ PSE dalam *website* mereka dapat mencantumkan informasi tentang: (1) Bagaimana cara menghubungi PSE; (2) Bagaimana menghubungi PSE Secara Online; (3) Kanal aduan bagi penyandang disabilitas

6.4 Apakah Anda menyediakan kanal aduan yang dapat digunakan oleh Pemilik Data Pribadi untuk melaporkan dampak terhadap kegagalan pelindungan Data Pribadi?

Contoh:

- Pengantar paket/ kurir mendistribusikan sejumlah obat kepada beberapa pasien dari Rumah Sakit. Kurir mengirimkan satu set obat ke pasien yang salah (Pasien A). Pasien A menelepon rumah sakit untuk mengadu. Rumah sakit menyadari resep tersebut sebenarnya untuk pasien yang berbeda dengan nama yang sama (Pasien B). Mereka menghubungi kurir yang kemudian menelepon kembali Pasien A, mengumpulkan barang-barang yang belum dibuka dan mengirimkannya kembali ke Pasien B. Pada titik ini, kurir memberi tahu Pasien B tentang kesalahan tersebut. Pasien B kemudian melayangkan keberatan kepada rumah sakit, karena mereka merasa informasi medis dan alamat mereka telah dibagikan secara tidak tepat dengan Pasien A.

6.5 Apakah Anda memiliki mekanisme mengenai tindakan mitigasi risiko dalam hal terjadi kebocoran atau kegagalan dalam pelindungan Data Pribadi?

PSE wajib menerapkan manajemen risiko dan menyediakan sistem pengamanan yang mencakup prosedur, sistem pencegahan dan penanggulangan terhadap ancaman dan serangan yang menimbulkan gangguan, kegagalan, dan kerugian. Yang dimaksud dengan "sistem pencegahan dan penanggulangan" antara lain *antivirus, anti spamming, firewall, intrusion detection, prevention system*, dan/atau pengelolaan sistem manajemen keamanan informasi.

Praktik yang baik:

- ☑ Tindakan pencegahan untuk menghindari terjadinya kegagalan dalam pelindungan Data Pribadi setidaknya mencakup kegiatan: (a). meningkatkan kesadaran sumber daya manusia di lingkungannya untuk memberikan pelindungan Data Pribadi dalam Sistem Elektronik yang dikelolanya; dan (b). mengadakan pelatihan pencegahan kegagalan pelindungan Data Pribadi dalam Sistem Elektronik yang dikelolanya bagi sumber daya manusia di lingkungannya.
- ☑ PSE sebaiknya menerapkan ISO 31000:2018 *Risk management — Guidelines*.

6.5 Apakah Anda memiliki mekanisme mengenai tindakan mitigasi risiko dalam hal terjadi kebocoran atau kegagalan dalam pelindungan Data Pribadi?

Praktik yang baik (lanjutan):

☑ Tindakan-tindakan mitigasi dapat berupa:

- meminimalkan penyimpanan data pribadi dengan tidak merekamnya;
- menghapus data pribadi segera setelah tujuan pemrosesan selesai;
- menjadwalkan penghapusan data pribadi setelah data tersebut diproses dan diaudit;
- batasan penggunaan data yang telah dikumpulkan untuk tujuan yang sangat spesifik, dengan memaksimalkan pelindungan hukum, organisasi, dan teknis untuk mencegah tujuan penggunaan data secara tidak sah;
- Adanya sistem, implementasi dan sumber daya kenal aduan yang responsif, didukung oleh sanksi yang tegas dan penegakannya. Berbagai masalah harus dianalisis, untuk menyusun langkah-langkah preventif dan mitigasi yang dapat diterima.

Contoh:

- Bank mengenkripsi semua data keuangan pelanggannya setiap saat. Bank mempertimbangkan untuk melakukan enkripsi ketika menilai kemungkinan adanya potensi ancaman terhadap kegagalan pelindungan data pribadi (misalnya, penipuan keuangan atau pencurian identitas).

A. PRINSIP-PRINSIP PEMROSESAN DATA PRIBADI

BAGIAN 07

Pemusnahan / Penghapusan Data Pribadi

7.1 Apakah Anda menyediakan mekanisme bagi Pemilik Data Pribadi untuk mengakhiri pemrosesan Data Pribadinya?

Pemrosesan data pribadi dilakukan dengan menjamin hak pemilik data pribadi berdasarkan peraturan perundang-undangan. Praktik yang baik bagi PSE juga menerapkan hak pemilik data yang berlaku secara internasional, khususnya apabila PSE memberikan layanan berskala global (seperti menerima pembayaran dengan mata uang asing).

Praktik yang baik:

- ☑ PSE memberikan hak pemilik data untuk mengakhiri atau menolak kegiatan pemrosesan data pribadi. Hak ini disampaikan secara tertulis atau verbal yang disampaikan oleh pemilik data.
- ☑ PSE menerima permohonan hak pengakhiran pemrosesan data pribadi dari bermacam-macam kontak yang mudah diakses oleh pemilik data (tidak semata-mata narahubung DPO).
- ☑ PSE memberikan pelatihan kepada karyawan dan DPO-nya agar lebih mengetahui ekspresi/pernyataan atas penolakan pemrosesan data pribadi. Pernyataan pengakhiran pemrosesan dapat bermacam-macam diungkapkan pemilik data sehingga perlu diketahui PSE.
- ☑ PSE tidak dapat memproses data pribadi yang sudah diminta dan disetujui hak pengakhiran pemrosesan data pribadi, kecuali PSE dapat menunjukkan ada dasar legalitas pemrosesan yang memiliki kekuatan hukum lebih tinggi atau adanya kepentingan yang sah lainnya dari PSE (yang sesuai dengan ketentuan peraturan perundang-undangan, diwajibkan secara eksplisit, dan terhadap kepentingan/tujuan yang aktual dan nyata).
- ☑ PSE membuat dokumentasi atas setiap permintaan hak dari pemilik data. PSE memiliki mekanisme pemberitahuan atas pelaksanaan hak pemilik data kepada vendor atau mitra kerjasamanya.

7.1 Apakah Anda menyediakan mekanisme bagi Pemilik Data Pribadi untuk mengakhiri pemrosesan Data Pribadinya?

Contoh:

- PSE langsung menghentikan pengiriman iklan/bahan promosi kepada pemilik data/pelanggan yang menolak *(unsubscribe)* layanan promosi PSE. Pemilik data berhak meminta berhenti berlangganan promosi dari PSE tanpa disertai alasan sekalipun.
- Pemilik data menolak data pribadinya diproses untuk profiling, PSE memberikan hak pemrosesan data pribadi yang disampaikan secara eksplisit oleh pemilik data (baik secara tertulis maupun verbal/konfirmasi via sambungan telepon).
- Pemilik data hanya dapat menggunakan hak pada bagian ini untuk tujuan pemrosesan penelitian ilmiah, statistik atau sejarah sepanjang dapat menunjukan bahwa pelaksanaan tujuan tersebut tidak dibutuhkan untuk tujuan/kepentingan publik.
- PSE membuat rekam cadang sistem dan dokumen elektroniknya *(backup archives)*. Pemilik data mengajukan hak terkait PDP kepada PSE tersebut, khususnya pemusnahan data. Setelah proses verifikasi, PSE memenuhi permintaan hak pemilik data terhadap sistem elektroniknya, baik sistem rekam cadang elektronik maupun sistem elektronik operasionalnya *(productive live system)*. PSE dapat memastikan bahwa sistem rekam cadang elektronik tidak akan dipulihkan/*restored* tanpa adanya pemeriksaan kepatuhan atas pemenuhan hak pemilik data.

7.2 Apakah Anda menyediakan mekanisme penghapusan dan/atau pemusnahan Data Pribadi sesuai dengan ketentuan peraturan perundang-undangan?

PSE wajib menghapus Informasi Elektronik dan/atau Dokumen Elektronik yang tidak relevan yang berada di bawah kendalinya atas permintaan pemilik data pribadi, yang mencakup (i) penghapusan (*right to erasure*); dan (ii) pengeluaran dari daftar mesin pencari (*right to delisting*). Khusus berkaitan pengeluaran dari daftar mesin pencari perlu dilakukan berdasarkan penetapan pengadilan.

Praktik yang baik:

- ☑ Penghapusan (*right to erasure*) terdiri atas Data Pribadi yang: (a) diperoleh dan diproses tanpa persetujuan pemilik Data Pribadi atau tanpa adanya dasar legalitas pemrosesannya; (b) telah ditarik persetujuannya oleh pemilik Data Pribadi; (c) diperoleh dan diproses dengan cara melawan hukum; (d) sudah tidak sesuai lagi dengan tujuan perolehan berdasarkan perjanjian dan/ atau ketentuan peraturan perundang-undangan; (e) penggunaannya telah melampaui waktu sesuai dengan perjanjian dan/atau ketentuan peraturan perundang-undangan; dan/atau (f) ditampilkan oleh PSE yang mengakibatkan kerugian bagi pemilik Data Pribadi.
- ☑ Pengeluaran dari daftar mesin pencari (*right to delisting*) dilakukan berdasarkan penetapan pengadilan yang dimohonkan orang yang bersangkutan sebagai pemilik Data Pribadi sesuai dengan ketentuan peraturan perundang-undangan. Permohonan wajib memuat: a. identitas pemohon; b. identitas PSE dan/atau alamat Sistem Elektronik; c. Data Pribadi yang tidak relevan di bawah kendali PSE; dan d. alasan permintaan penghapusan.

7.2 Apakah Anda menyediakan mekanisme penghapusan dan/atau pemusnahan Data Pribadi sesuai dengan ketentuan peraturan perundang-undangan?

Praktik yang baik (lanjutan):

- ☑ PSE wajib menyediakan mekanisme penghapusan Informasi Elektronik dan/atau Dokumen Elektronik yang sudah tidak relevan sesuai dengan ketentuan peraturan perundang-undang.
- ☑ Mekanisme penghapusan setidaknya memuat ketentuan mengenai: (i) penyediaan saluran komunikasi antara PSE dengan pemilik Data Pribadi; (ii) fitur penghapusan data yang tidak relevan yang memungkinkan pemilik Data Pribadi melakukan penghapusan Data Pribadinya; dan (iii) pendataan atas permintaan penghapusan Informasi Elektronik dan/atau Dokumen Elektronik yang tidak relevan.
- ☑ Pada PSE lingkup publik, ketentuan mengenai mekanisme penghapusan dapat dibuat oleh K/L terkait setelah berkoordinasi dengan Menteri Kominfo.

Contoh:

- Penyedia aplikasi pinjaman *online* memberikan opsi penghapusan data pada aplikasi untuk memudahkan penggunaan aplikasi mengajukan permintaan penghapusan data.
- Contoh putusan pengadilan terkait *right to delisting* di Indonesia belum dapat ditemukan. Namun, hak ini merupakan hak yang diminta salah satunya oleh artis Kartika Putri saat menyadari fotonya sebelum berhijab masih beredar di Internet.

7.3 Apakah Anda memiliki kebijakan retensi terkait penyimpanan Data Pribadi?

Pemrosesan data pribadi dimusnahkan kecuali masih dalam masa retensi sesuai dengan peraturan perundang-undangan. Kebijakan retensi mencantumkan jenis data pribadi belum dimusnahkan oleh PSE, untuk apa PSE menggunakannya, dan berapa lama Anda bermaksud menyimpannya. Kebijakan ini membantu Anda menetapkan dan mendokumentasikan periode retensi standar untuk bermacam-macam kategori Data Pribadi.

Praktik yang baik:

- ☑ Adanya batas waktu penyimpanan data pribadi dan PSE melakukan analisis secara berkala kapan suatu data pribadi tidak lagi dibutuhkan sehingga perlu dimusnahkan.
- ☑ PSE lingkup publik menyimpan data pribadi dalam wilayah Indonesia dengan menggunakan layanan penyimpanan sendiri atau milik pihak ketiga yang layanannya yang berkualitas tinggi dan bersertifikasi.
- ☑ PSE menyimpan data pribadi yang telah diverifikasi keakuratannya dan disimpan dalam bentuk data terenkripsi.
- ☑ PSE menyimpan data pribadi paling singkat selama 5 tahun, kecuali diatur berbeda berdasarkan peraturan perundang-undangan. PSE menganalisis adanya batas waktu penyimpanan dalam regulasi.
- ☑ Setelah tujuan pemrosesan dipenuhi, PSE menyimpan data pribadi yang telah diubah/dibuat anonim sehingga upaya pengamanannya tidak seketat pengamanan data pribadi.
- ☑ PSE tidak menyimpan data pribadi melebihi masa retensi penyimpanan data pribadi dan tidak dapat menggunakan alasan bahwa data tersebut mungkin dapat digunakan kembali di kemudian hari sebagai dasar menyimpan data pribadi.
- ☑ PSE menyampaikan jangka waktu penyimpanan data pribadi kepada pemilik data pada saat perolehan data pribadi.

7.3 Apakah Anda memiliki kebijakan retensi terkait penyimpanan Data Pribadi?

Contoh:

- PSE memberikan opsi/fitur penghapusan data pribadi (dalam aplikasi yang disediakannya) kepada pelanggannya dalam hal ia meng-*uninstall* atau menyatakan menghentikan penggunaan layanan yang diberikan PSE.
- PSE tidak dapat menyimpan data pribadi tanpa adanya batas waktu (permanen), kecuali data tersebut dibuat benar-benar anonim. PSE memusnahkan data pribadi pelanggannya yang meminta pemusnahan atau meninggal dunia.
- PSE memusnahkan data pribadi atas calon pelamar kerja yang tidak lolos seleksi/proses rekrutmen setelah masa retensi tertentu berdasarkan peraturan perundang-undangan. PSE menghapus data pribadi dari mantan karyawannya, termasuk data pribadi keluarganya yang telah diungkapkan oleh karyawan.
- PSE menagih utang debitur perseorangan, dan ketiga debitur sudah melunasi hutangnya dan melampai masa retensi berdasarkan peraturan perundang-undangan, data tersebut dimusnahkan.
- PSE menganalisis atau bertanya kepada otoritas atau advokat/konsultan PDP mengenai adanya batasan waktu penyimpan data pribadi yang diatur dalam peraturan perundang-undangan *(statutory data retention period)*.

B. PENGIRIMAN DAN PENGUNGKAPAN DATA PRIBADI

1 Apakah Anda melakukan Pengiriman Data Pribadi ke Luar Wilayah Indonesia?

Pengiriman Data Pribadi yang dikelola oleh PSE yang berdomisili di wilayah negara Republik Indonesia ke luar wilayah Indonesia meliputi : (i) pengiriman Data Pribadi yang semula disimpan di Indonesia ke luar negeri; atau (ii) data WNI disimpan secara langsung pada *database* yang berada di luar negeri. Transfer data bukan berarti transit *(route)* yang mana data dikirim dari negara A ke B tetapi transit melalui C. Transit ke C ini bukan transfer data sepanjang pada saat transit, data pribadi tidak diakses atau diubah.

Praktik yang baik:

- ☑ PSE yang akan melakukan pengiriman Data Pribadi ke Luar Wilayah Indonesia memastikan bahwa PSE telah mendapatkan persetujuan tertulis dari Pemilik Data Pribadi atau memiliki dasar hukum lain untuk melakukan pemrosesan Data Pribadi (misalnya dalam hal pemenuhan pelindungan kepentingan yang sah (*vital interest*) pemilik Data Pribadi).
- ☑ Dalam hal tidak terdapat persetujuan tertulis atau dasar hukum lain untuk melakukan pengiriman Data Pribadi, PSE meminta persetujuan tambahan dari pemilik Data Pribadi sebelum melakukan pengiriman Data Pribadi (melalui formulir persetujuan tambahan atau persetujuan terhadap pembaharuan terhadap kebijakan privasi yang kemudian disampaikan kepada pemilik data secara langsung saat mereka menggunakan layanan atau melalui email).
- ☑ PSE memperhatikan ketentuan mengenai koordinasi dengan Kominfo (akan dirinci pada *slide* selanjutnya).

1 Apakah Anda melakukan Pengiriman Data Pribadi ke Luar Wilayah Indonesia?

Contoh:

- Perusahaan multinasional yang sedari awal memahami bahwa untuk menjalankan operasionalnya memerlukan pengiriman Data Pribadi ke kantor pusatnya atau perusahaan lain dalam grup perusahaannya (di luar negeri), maka sedari awal proses pengumpulan Data Pribadi, perusahaan tersebut meminta persetujuan individual yang berkaitan termasuk juga untuk kegiatan pengiriman data ke luar wilayah Indonesia.
- Perusahaan jasa wisata dan travel di Australia menawarkan paket liburan di Australia kepada perusahaan di Indonesia. Dalam rangka program liburan karyawan, perusahaan Indonesia mengirimkan data ke perusahaan Australia tersebut untuk keperluan pemesanan hotel, tiket perjalanan, tiket wisata. Perusahaan Indonesia tersebut melakukan kegiatan transfer dan wajib memenuhi ketentuan transfer internasional berdasarkan regulasi PDP Indonesia.
- PSE *e-commerce* di Indonesia mentransfer data pribadi pelanggannya ke perusahaan di Malaysia secara elektronik melalui server di Singapura – server transit. Sepanjang data tersebut dijamin tidak diakses atau diubah selama transit di Singapura, maka transfer hanya terjadi kepada perusahaan di Malaysia. PSE wajib memenuhi ketentuan regulasi PDP di Indonesia.
- Penyedia layanan *cloud computing* menggunakan penyimpanan data di berbagai negara, penyedia tersebut tunduk pada ketentuan PDP, antara lain, menjamin dan menunjukkan kegiatan transfer data pribadi dilakukan dengan mengimplementasi upaya-upaya pelindungan data, seperti mengadopsi peraturan keanggotaan *(code of conduct)* asosiasi bisnis *cloud computing* yang relevan (contoh: Cloud Security Alliance dan Pan-Asian E-Commerce Alliance).

2 Apabila Anda melakukan Pengiriman Data Pribadi ke Luar Wilayah Indonesia, apakah Anda melakukan koordinasi dengan Kementerian Komunikasi dan Informatika?

PSE yang mengirim Data Pribadi ke luar negeri harus melakukan koordinasi dengan Kominfo dengan cara:

(i) melaporkan rencana pelaksanaan pengiriman Data Pribadi menggunakan form pada tautan berikut https://komin.fo/LaporRencanaTransferDP,

(ii) meminta advokasi (apabila diperlukan), dan

(iii) melaporkan hasil pelaksanaan kegiatan menggunakan form pada tautan berikut https://komin.fo/LaporHasilTransferDP.

Praktik yang baik:

- ☑ Selain adanya persetujuan dari pemilik data, PSE harus melaporkan rencana dan proses pelaksanaan pengiriman Data Pribadi ke luar negeri ke Kominfo.
- ☑ Bentuk laporan mengenai rencana pengiriman Data Pribadi harus memuat paling sedikit nama jelas negara tujuan, nama jelas subjek penerima, tanggal pelaksanaan, dan alasan/tujuan pengiriman.
- ☑ Untuk pelaksanaan, tidak terdapat format yang diatur dan dengan demikian PSE disarankan melaporkan secara berkala mengenai pelaksanaan pengiriman Data Pribadi.
- ☑ PSE dapat meminta advokasi berupa konsultasi dengan Kominfo (apabila diperlukan).
- ☑ PSE harus pula mematuhi ketentuan mengenai pertukaran Data Pribadi lintas batas negara (saat ini belum terdapat peraturan yang dimaksud) tetapi PSE dapat mengadopsi peraturan anggota *(code of conduct)* asosiasi bisnis yang mengatur aspek *good practices* keamanan data dan PDP.

2 Apabila Anda melakukan Pengiriman Data Pribadi ke Luar Wilayah Indonesia, apakah Anda melakukan koordinasi dengan Kementerian Komunikasi dan Informatika?

Contoh:

- Perusahaan multinasional yang memiliki kantor pusat di luar negeri umumnya akan mengirim/mempertukarkan banyak informasi elektronik (termasuk data pribadi) ke entitas lain di negara lain untuk kepentingan operasional. Dalam hal ini, ketentuan terkait dengan notifikasi pengiriman Data Pribadi kepada Kominfo menjadi relevan.
- Data diplomasi dapat memuat informasi tentang diri seseorang, kementerian luar negeri dalam melakukan penyebarluasan data diplomasi, yaitu kegiatan pemberian akses, pendistribusian, dan pertukaran data perlu mematuhi ketentuan PDP, khususnya dalam hal terdapat data pribadi yang dikumpulkan dan diolah melalui sistem elektronik sebagai bagian dari data diplomasi. Hal ini sebagaimana ditegaskan dalam peraturan menteri luar negeri mengenai tata kelola data diplomasi kementerian luar negeri dan perwakilan republik Indonesia.

3 Apakah Anda memiliki kebijakan dan prosedur dalam hal terdapat permintaan akses dari aparat penegak hukum dan kementerian/lembaga terkait Data Pribadi yang Anda kelola?

PSE wajib memberikan akses ke data pribadi yang terdapat dalam sistem elektronik yang dikuasai/diselenggarakan oleh PSE tersebut atas permintaan yang sah dari aparat penegak hukum (kepolisian, jaksa, dan Penyidik PNS) dan K/L di Indonesia. Data pribadi yang diminta adalah yang relevan dan sesuai dengan kebutuhan penegakan hukum pidana dan pengawasan K/L yang permintaan aksesnya dikeluarkan secara resmi sesuai ketentuan regulasi.

Praktik yang baik:

- PSE menyertakan dalam kebijakan privasi atau formulir persetujuan pada saat pengumpulan data adanya ketentuan pemberian akses terhadap data pribadi yang diajukan oleh APH dan/atau K/L dalam rangka pengawasan K/L dan penegakan hukum pidana.
- PSE menyusun dan menyampaikan aturan internal kepada semua karyawan dan afiliasinya terkait kebijakan dan mekanisme perusahaan dalam memberikan akses ke data pribadi yang dikuasai/diselenggarakannya dalam rangka pengawasan K/L dan penegakan hukum pidana.
- PSE menerapkan ketentuan peraturan yang mengatur mengenai permintaan akses terhadap informasi dan/atau dokumen elektronik yang berlaku di Kominfo dan/atau instansi penyelenggara negara lain.

3 Apakah Anda memiliki kebijakan dan prosedur dalam hal terdapat permintaan akses dari aparat penegak hukum dan kementerian/lembaga terkait Data Pribadi yang Anda kelola?

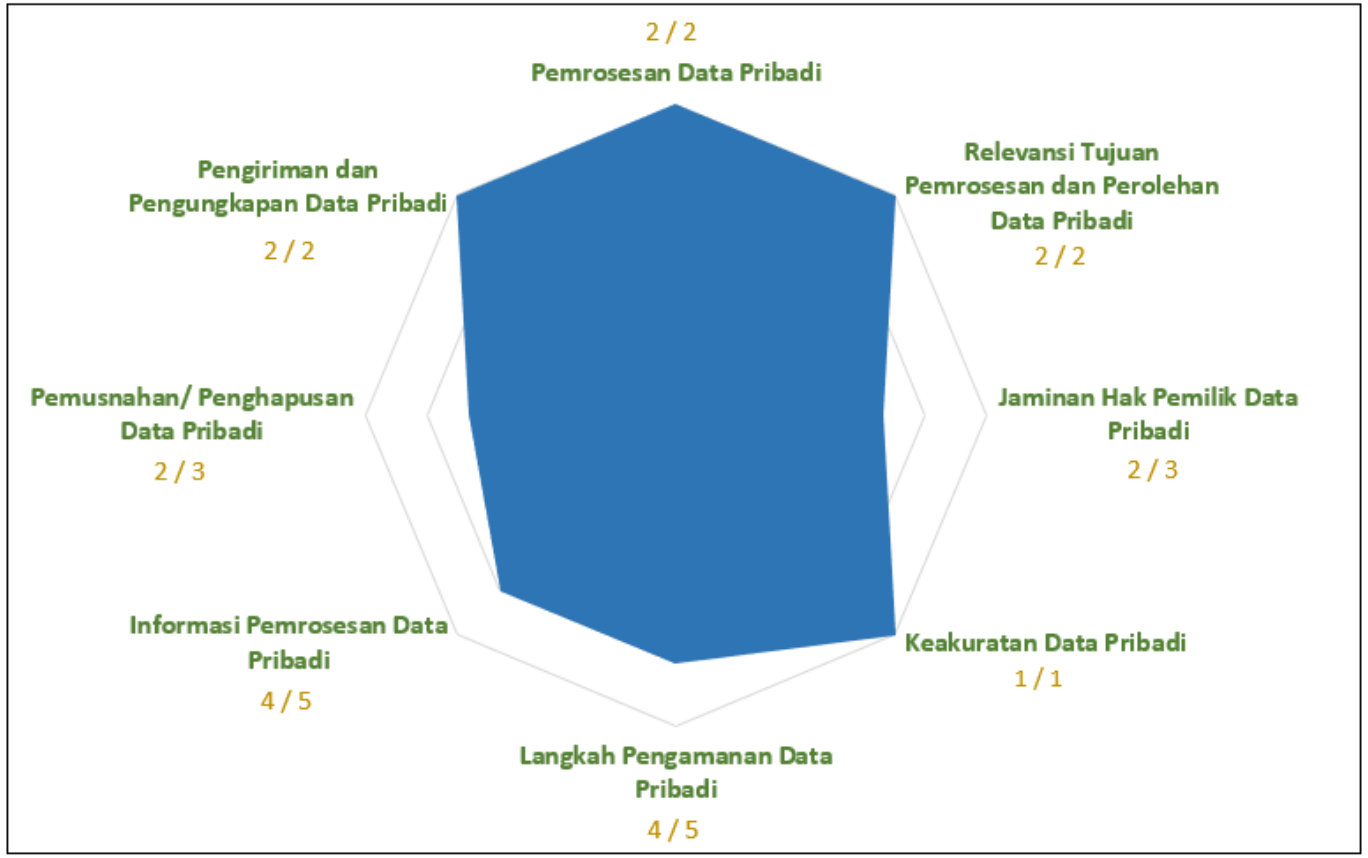
Contoh:

- Perusahaan telekomunikasi wajib memberikan informasi pelanggan dalam hal informasi dibutuhkan untuk proses peradilan pidana. Perusahaan telekomunikasi menginformasikan hal ini kepada pelanggan dalam syarat dan ketentuan pada saat pengaktivasian produk.
- Ditjen Imigrasi Kementerian Hukum dan HAM menyelenggarakan Sistem Informasi Manajemen Keimigrasian **("SIMKIM")** yaitu sistem informasi dan komunikasi yang digunakan untuk mengumpulkan, mengolah, dan menyajikan informasi guna mendukung operasional, manajemen, dan pengambilan keputusan dalam melaksanakan fungsi keimigrasian (perihal lalu lintas orang). Berdasarkan UU Keimigrasian, SIMKIM dapat diakses oleh instansi dan/atau lembaga pemerintahan terkait sesuai dengan tugas dan fungsinya. Pemberian akses ini wajib memperhatikan ketentuan PDP, antara lain, pengamanan dan kerahasiaan data pribadi, serta adanya DPO.

HASIL ASESMEN
IMPLEMENTASI PELINDUNGAN DATA PRIBADI

HASIL ASESMEN
IMPLEMENTASI PELINDUNGAN DATA PRIBADI

Persentase Kepatuhan PDP	19 / 23	83%	Menengah



Keterangan
Persentase Kepatuhan PDP

- 91% - 100 % : Tinggi
- 51% - 90% : Menengah
- 0% - 50% : Rendah

Hasil Asesmen

Informasi Pemrosesan Data Pribadi — Nilai : 2 / 5 — Sangat Kurang

Saran

- Sebagai pengendali data, Anda wajib melakukan dokumentasi seluruh kegiatan pemrosesan Data Pribadi, termasuk transfer data ke luar negeri, jadwal penghapusan data yang berlaku dari setiap kategori data, dan (sepanjang memungkinkan) deskripsi langkah teknis operasional untuk melindungi Data Pribadi.
- Anda harus menyediakan kanal aduan yang dapat digunakan oleh Pemilik Data Pribadi untuk melaporkan dampak terhadap kegagalan perlindungan Data Pribadi. Hal ini bertujuan untuk mengetahui Pemilik Data Pribadi yang terdampak, dan memberikan saran untuk membantu Pemilik Data Pribadi melindungi diri dari dampak selanjutnya akibat kegagalan pelindungan Data Pribadi.
- • Anda harus memastikan Anda untuk mengatasi kegagalan pelindungan Data Pribadi.
  • Anda harus memiliki langkah mitigasi, tindakan perbaikan, dan manajemen risiko untuk memastikan kegagalan pelindungan Data Pribadi tidak terjadi lagi.

Pemusnahan/ Penghapusan Data Pribadi — Nilai : 1 / 3 — Sangat Kurang

Saran

- Anda harus memiliki mekanisme bagi Pemilik Data Pribadi untuk mengakhiri pemrosesan Data Pribadi yang dapat dilakukan dengan justifikasi alasan kesalahan pada data, ketidakjelasan dasar hukum, atau sekedar pembatalan akan pemrosesan dari pihak Pemilik Data Pribadi.
- • Anda harus memiliki mekanisme untuk memastikan penghapusan dan/atau pemusnahan Data Pribadi dari Sistem Elektronik Anda.
  • Pengendali data harus melaksanakan permintaan penghapusan ini kecuali ada suatu dasar hukum yang jelas mengapa data tersebut harus tetap disimpan contohnya demi kepentingan umum atau penelitian.
  • Jika permintaan penghapusan dilayangkan terkait dengan tujuan pemrosesan yang telah kedaluwarsa, maka Anda harus melakukan pemeriksaan lebih lanjut jika ada data lain yang masih Anda simpan namun tanpa tujuan yang jelas.

Pengiriman dan Pengungkapan Data Pribadi — Nilai : 0 / 2 — Tidak Memenuhi

Saran

- • Anda harus melakukan koordinasi mengenai pengiriman Data Pribadi keluar wilayah indonesia dengan Kementerian Kominfo.
  • Koordinasi tersebut disampaikan dalam format Rencana pengiriman data keluar negeri pada saat sebelum pelaksanaan pengiriman data serta format laporan pelaksanaan pengiriman data keluar negeri pada saat pengiriman data telah selesai dilakukan.
- • Anda harus memiliki kebijakan dan prosedur untuk permintaan Data Pribadi yang dilakukan oleh aparat penegak hukum.
  • Anda mempertimbangkan proporsionalitas dari tujuan dan keperluan berbagi Data Pribadi dengan aparat penegak hukum.
  • Anda hanya membagikan Data Pribadi yang relevan dan memadai dalam jumlah minimum yang diperlukan.

Pemrosesan Data Pribadi — Nilai : 2 / 2 — Sudah Memenuhi

Anda sudah memenuhi semua poin asesmen dalam kategori ini.

Relevansi Tujuan Pemrosesan dan Perolehan Data Pribadi — Nilai : 2 / 2 — Sudah Memenuhi

Anda sudah memenuhi semua poin asesmen dalam kategori ini.

Jaminan Hak Pemilik Data Pribadi — Nilai : 2 / 3 — Kurang

Saran

- • Anda harus memiliki prosedur untuk memastikan untuk menanggapi permintaan salinan Data Pribadi dari Pemilik Data Pribadi
  • Anda harus memiliki mekanisme yang memungkinkan Pemilik Data Pribadi memiliki akses untuk mendapatkan informasi yang diinginkan terkait pemrosesan Data Pribadinya.
- • Dalam memenuhi permintaan perolehan Data Pribadi dari Pemilik Data, Anda harus memastikan informasi tersebut disampaikan dengan menggunakan metode yang aman.
  • Data Pribadi yang diperoleh oleh Pemilik Data harus dalam format terstruktur dan umum digunakan.
  • Anda harus memastikan bahwa data yang diminta adalah Data Pribadi dari Pemilik Data yang melakukan permintaan akses atau salinan Data Pribadi.

Langkah Pengamanan Data Pribadi — Nilai : 2 / 5 — Sangat Kurang

Saran

- • Anda harus memiliki kebijakan pengelolaan Data Pribadi atau aturan internal (atau yang setara) dan mengambil langkah-langkah untuk memastikan kebijakan tersebut diterapkan.
  • Apabila memungkinkan dan dibutuhkan, Anda dapat memiliki kebijakan tambahan dan memastikan bahwa kontrol diterapkan.
  • Anda harus meninjau kebijakan dan tindakan secara berkala dan jika perlu, memperbaikinya.
- Anda harus memiliki program sosialisasi terhadap aturan internal sebagai salah satu langkah awal untuk memastikan kebijakan diketahui dan kemudian diterapkan oleh seluruh pegawai dan pihak terkait.
- Anda harus memiliki program internal terkait peningkatan kesadaran perlindungan Data Pribadi untuk memberikan perlindungan Data Pribadi dalam Sistem Elektronik yang Anda kelola.
- • Anda wajib menunjuk Pejabat atau Petugas Yang Melaksanakan Fungsi Pelindungan Data Pribadi jika Anda melakukan aktivitas pemrosesan Data Pribadi.
  • Pejabat atau Petugas yang melaksanakan fungsi Pelindungan Data Pribadi membantu Anda memantau kepatuhan internal, menginformasikan dan memberi nasihat tentang kewajiban perlindungan data Anda, memberikan saran terkait Analisis Dampak Perlindungan Data (DPIA), dan bertindak sebagai narahubung untuk subjek data dan instansi pengawas pelindungan Data Pribadi.

Keterangan

100 % : Sudah Memenuhi

50-99% : Kurang

1-49% : Sangat Kurang

0% : Tidak memenuhi

KOMINFO

Pelindungan Data Pribadi
aman, andal, dan bertanggung jawab